

网络空间安全技术

CH1 网络空间安全概述

1. 信息安全的基本目标

机密性 (Confidentiality)

完整性 (Integrity)

可用性 (Availability)

机密性：确保信息没有非授权的泄漏，不被非授权的个人、组织和计算机程序使用

完整性：确保信息没有遭到篡改和破坏

可用性：确保拥有授权的用户或程序可以及时、正常使用信息

例题：存在一个算法在某个任务上同时满足三个基本目标 (✓)

2. 网络空间四要素

网络空间四要素：网络空间载体（设施）；网络空间资源（数据）；网络活动主体（用户）；网络活动形式（操作）

网络空间载体：设施，信息通信技术系统的集合

网络操作对象：数据，表达人类所能理解的意图的信号状态

网络活动主体：用户，网络活动的主体要素，属于人的代理

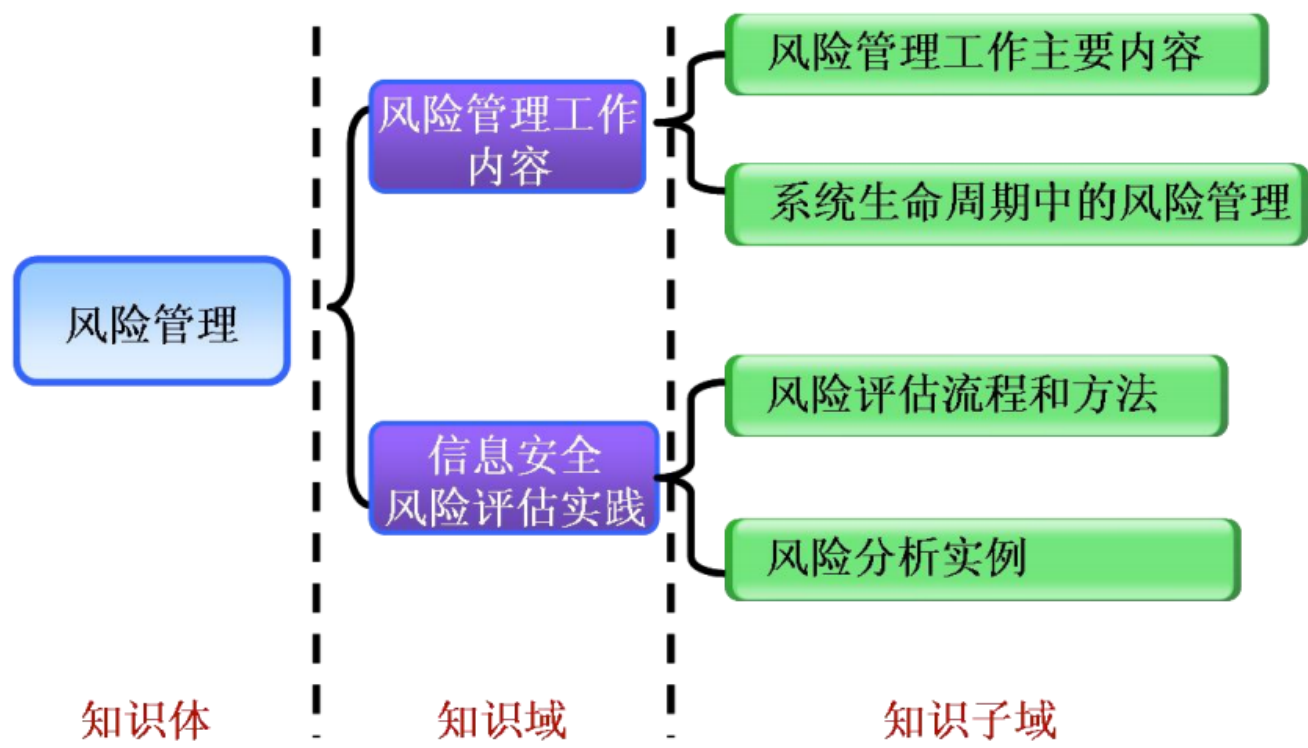
网络活动形式：操作，对数据的加工、存储、传输、展示等服务形式

3. 网络空间的一般性定义

网络空间是一种人造的电磁空间，其以互联网、各种通信系统与电信网、各种传播系统与广电网、各种计算机系统、各类关键工业设施中的嵌入式处理器和控制器等信息通信技术基础设施为载体，用户通过在其上对数据进行创造、存储、改变、传输、使用、展示等操作，以实现特定的信息通信技术活动。

CH2 网络安全的基本定义+组成

考察概念的含义



1. 网络空间安全风险

1.1 概念

定义一：（GB/Z 24364《信息安全风险管理指南》）信息安全风险管理是识别、控制、消除或最小化可能影响系统资源的不确定因素的过程。

定义二：在组织机构内部识别、优化、管理风险，使风险降低到可接受水平的过程。

了解风险+控制风险=管理风险

1.2 网络空间安全风险术语

资产（Asset）

威胁源（Threat Agent）

威胁（Threat）

脆弱性（Vulnerability）

控制措施（Countermeasure,safeguard,control）

可能性（Likelihood,Probability）

影响（Impact,loss）

风险（Risk）

残余风险（Residual Risk）

概念：指采取了安全措施后，信息系统仍然可能存在的风险。

有些残余风险是在综合考虑了安全成本与效益后不去控制的风险（风险管理是要付出代价的）

残余风险应受到密切监视，它可能会在将来诱发新的安全事件（此一时彼一时）

风险列表中有10类风险，根据风险成本效益分析，只有前8项需要控制，则另2项为残余风险，一段时间内系统处于风险可接受水平。

1.3 风险管理工作内容

建立背景，风险评估，风险处理，批准监督

1.3.1 风险处理

概念

风险处理是为了将风险始终控制在可接受的范围内。

做法：

现存风险判断：判断信息系统中哪些风险可以接受，哪些不可以

处理目标确认：不可接受的风险需要控制到怎样的程度

处理措施选择：选择风险处理方式，确定风险控制措施

处理措施实施：制定具体安全方案，部署控制措施

常用的四类风险处置方法

减低风险，转移风险，规避风险，接受风险

1.3.2 风险评估（见下节）

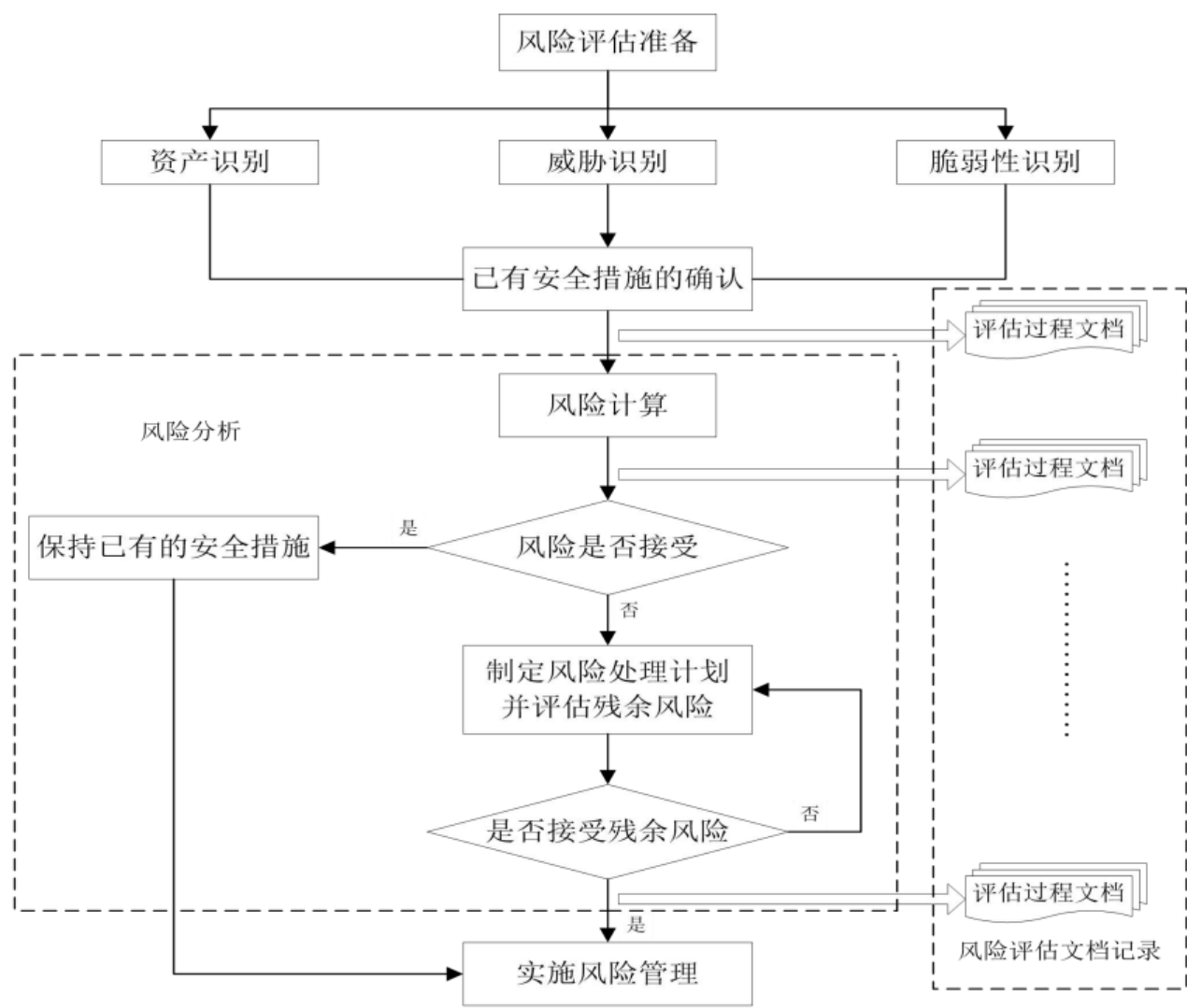
2. 风险评估

2.1 风险评估、检查评估和等级保护测评之间的关系

等保测评、安全检查都是在既定安全基线的基础上开展的符合性测评，其中等保测评是符合国家安全要求的测评，安全检查是符合行业主管安全要求的符合性测评。

而风险评估是在国家、行业安全要求的基础上，以被评估系统特定安全要求为目标而开展的风险识别、风险分析、风险评价活动。

2.2 实施流程



四个阶段：

阶段1:评估准备（定性，定量评估方法）

定性的风险评估方法

概念：依据研究者的知识、经验、历史教训、政策走向及特殊变例等非量化资料对风险做出判断；采用文字形式或叙述性数值范围描述风险的影响程度和可能性的大小（如高、中、低等）

典型的定性评估方法：

因素分析法，逻辑分析法，历史比较法，德尔斐法

定量的风险评估方法

运用数量指标来对风险进行评估，采用量化的数值描述后果（估计出可能损失的金额）和可能性（概率或频率）

定量的评估方法：

因子分析法，聚类分析法，时序模型，回归模型，风险图法，决策树法等

阶段2:风险识别（资产识别→威胁识别→脆弱性识别→风险分析）

脆弱性识别

脆弱性识别与威胁识别是何关系？（脆弱性识别的目标）

验证：以资产为对象，对威胁识别进行验证

脆弱性识别的难点是什么？

三性：隐蔽性、欺骗性、复杂性

脆弱性分类（基本类型）

管理脆弱性（如缺少管理制度）

结构脆弱性（如安全域划分不当）

操作脆弱性（如安全审计员业务生疏）

技术脆弱性（如系统有 bug）

物理脆弱性（如一层的窗子没有防护栏）

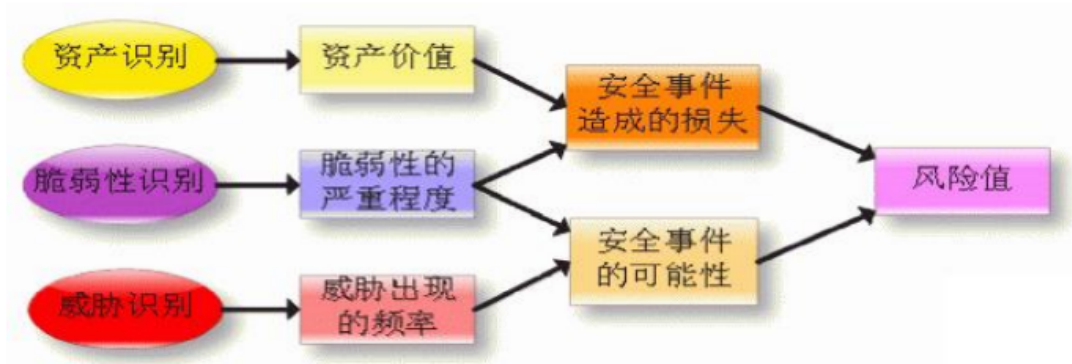
渗透测试

概念：完全模拟黑客可能使用的攻击技术和漏洞发现技术，对重点目标系统的安全作深入的探测，发现系统最脆弱的环节。

渗透测试的目的不是发现系统所有的问题，而是从一个侧面反映系统现有的安全状况和安全强度，从而以一种直观的方式增强单位的信息安全认知度，提高单位对信息安全的重视程度。根据用户方需求决定是否采用。

风险分析

GB/T 20984-2007 《信息安全风险评估规范》给出信息安全风险分析思路



$$\text{风险值} = R(A, T, V) = R(L(T, V), F(Ia, Va))$$

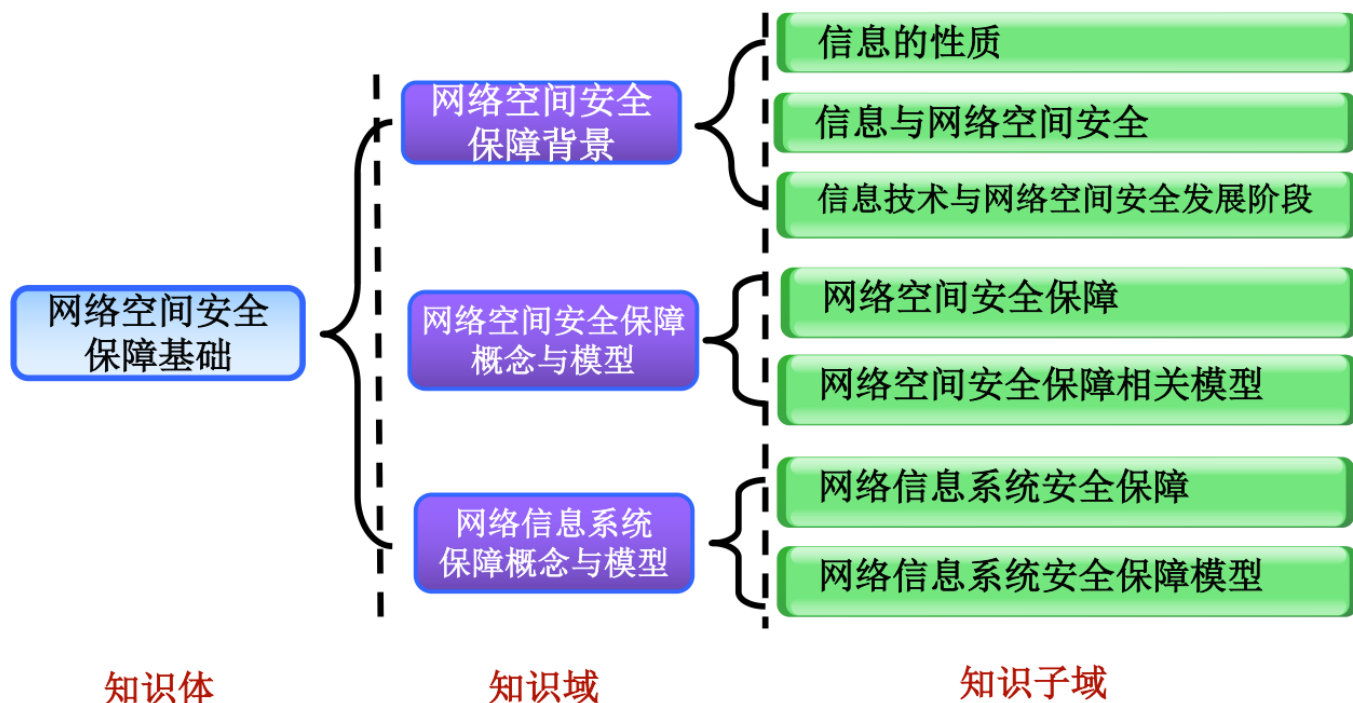
- **R**表示安全风险计算函数
- **A**表示资产
- **T**表示威胁
- **V**表示脆弱性
- **Ia**表示安全事件所作用的资产价值
- **Va**表示脆弱性严重程度
- **L**表示威胁利用资产的脆弱性导致安全事件的可能性
- **F**表示安全事件发生后造成的损失

阶段3:风险评价

阶段4:风险处理

3. 国产化替代

CH3 信息与网络空间安全保障



1. 网络空间安全保障概念与模型

1.1 PDR模型



响应 (Response)

应急响应在安全模型中占有重要地位，是解决安全问题的最有效办法。解决安全问题就是解决**紧急响应**和**异常处理**问题，因此，**建立应急响应机制**，形成**快速安全响应的能力**，对网络和系统而言至关重要。

保护 (Protection)

保护就是采用一切可能的措施来保护网络、系统以及信息的安全。保护通常采用的技术及方法主要包括**加密、鉴别、访问控制、防火墙以及防病毒**等。

检测 (Detection)

检测可以了解和评估网络和系统的安全状态，为安全防护和安全响应提供依据。检测技术主要包括入侵检测、漏洞检测以及网络扫描等技术。

1.2 PDR演变：PDRR模型



PDRR模型是：保护（Protect）、检测（Detect）、反应（React）、恢复（Restore）的有机结合。该模型强调的是自动故障恢复能力。

- 保护（Protect）作为基础，将保护视为活动过程
- 采用检测（Detect）手段来发现安全漏洞
- 采用应急响应（React）措施对付各种入侵
- 在系统被入侵后，要采取相应的措施将系统恢复（Restore）到正常状态。

1.3 PPDR模型及其数学法则



P2DR模型示意图

- Policy 策略：模型的核心，所有的防护、检测、响应都是依据安全策略实施的。
- Protection 防护：通过传统的静态安全技术和方法提高网络的防护能力

Detection 检测：利用检测工具，监视、分析、审计网络活动，了解判断网络系统的安全状态。使安全防护从被动防护演进到主动防御，是整个模型动态性的体现。

Response 反应：在检测到安全漏洞和安全事件时，通过及时的响应措施将网络系统的安全性调整到风险最低的状态。

数学模型

假设S系统的防护、检测和反应的时间关系如下：

P_t =防护时间(有效防御攻击的时间)

D_t =检测时间（发起攻击到检测到的时间）

R_t =反应时间（检测到攻击到处理完成时间）

E_t =暴露时间

则该系统防护、检测和反应的时间关系如下：

如果 $P_t > D_t + R_t$ ，那么S是安全的；

如果 $P_t < D_t + R_t$ ，那么 $E_t = (D_t + R_t) - P_t$ 。

1.4 IATF-深度防御保障模型

1.4.1 何谓“深度防御”

1. IATF强调人、技术、操作这三个核心要素，从多种不同的角度对信息系统进行防护。
2. IATF关注四个信息安全保障领域（**三保护一支撑**：保护本地计算环境，保护区域边界，保护网络和基础设施，支撑性基础设施）
3. 在此基础上，对信息信息系统就可以做到多层防护，实现组织的任务/业务运作。这样的防护被称为“深度防护战略（Defense-in-Depth Strategy）”。

IATF的安全需求划分

IATF定义了四个主要的技术焦点领域（**三保护一支撑**）：

- 本地计算环境
- 区域边界
- 网络和基础设施
- 支撑性基础设施

这四个领域构成了完整的信息保障体系所涉及的范围。

在每个领域范围内，IATF都描述了其特有的安全需求和相应的可供选择的技术措施。

2. 应急响应——事件的分级

2.1 四级/一般

安全事件未造成业务中断，或中断时间少于10分钟，并且未造成业务系统数据损坏、丢失。例如，误操作加入了一项访问控制列表，造成业务系统暂时无法访问，及时发现并进行了恢复。

2.2 三级/较大

安全事件造成业务中断或间断，中断时间10-30分钟，并且未造成业务系统数据损坏、丢失。例如，蠕虫病毒造成局部网络拥塞，未对数据破坏，及时进行了防毒与恢复。

2.3 二级/重大

安全事件造成业务中断或间断时间在30-60分钟，或者业务系统数据部分损坏、丢失，可以通过备份进行恢复。例如，某服务器被入侵后，系统数据被删除，被删除数据有备份。

2.4 一级/特别重大

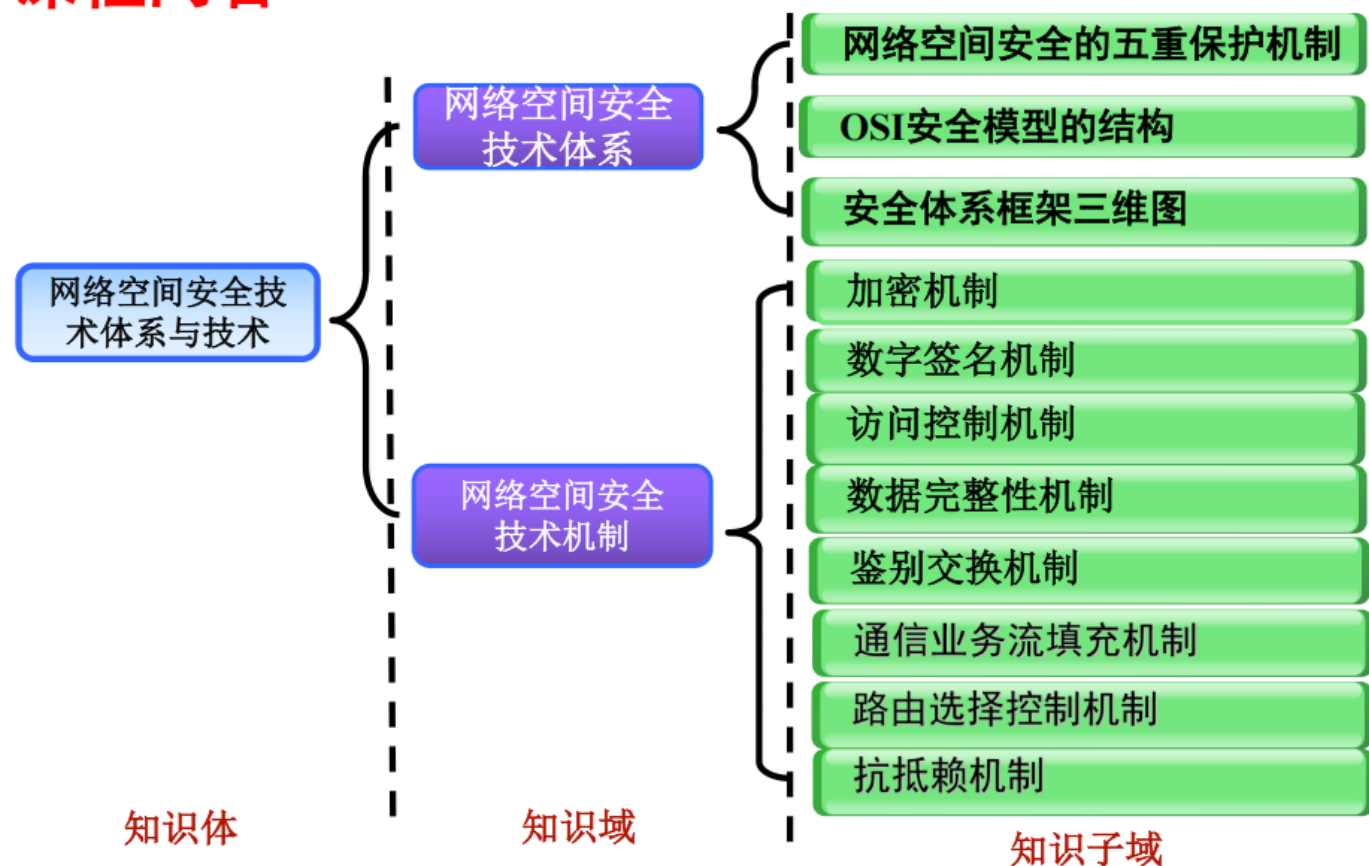
安全事件造成业务中断或间断时间在60分钟以上，或者业务系统数据损坏、丢失，并且无法恢复，或者重要数据泄露，或者业务系统或网络被破坏或损坏，并且预计在60分钟内无法恢复。安全事件造成一级敏感数据泄漏。

2.5 特殊时期

特殊时期（如重大活动、重大赛事等）发生的安全事件的级别应在原有级别上提升一级，特别重大安全事件级别不再向上提升。

CH4-网络安全安全技术体系与技术

课程内容



1. 开放系统互连安全体系结构（OSI）

1.1 安全服务

鉴别服务 (Authentication)

确保通信双方的身份是真实的，防止有人冒充。

访问控制服务 (Access Control)

限制谁可以访问什么资源。防止未授权的用户使用网络资源或获取数据。

数据机密性服务 (Data Confidentiality)

确保数据在传输过程中不被泄露给未经授权的人。即使被截获了，别人也看不懂。

数据完整性服务 (Data Integrity)

确保数据在传输过程中没有被篡改、删除或插入。保证收到的数据和发出的数据一模一样。

抗抵赖服务 (Non-repudiation)

防止通信双方在事后否认自己曾经做过行为

1.2 安全机制

1. **加密**。加密既能为数据提供机密性，也能为通信业务流提供机密性，还为其它机制提供补充。加密机制可配置在多个协议层次中。

2. **数字签名机制**。可以完成对数据单元的签名工作，也可实现对已有签名的验证工作。数字签名必须不可伪造和不可抵赖。
3. **访问控制机制**。按实体所拥有的访问权限对指定资源进行访问，对非授权或不正当的访问应有一定的报警或审计跟踪方法。
4. **数据完整性机制**。发送端产生一个与数据单元相关的附加码，接收端通过对数据单元与附加码的相关验证控制数据的完整性。
5. **鉴别交换机制**。可以使用密码技术，由发送方提供，而由接收方验证来实现鉴别。通过特定的“握手”协议防止鉴别“重放”。
6. **通信业务填充机制**。业务分析，特别是基于流量的业务分析是攻击通信系统的主要方法之一。通过通信业务填充来提供各种不同级别的保护。
7. **路由选择控制机制**。针对数据单元的安全性要求，可以提供安全的路由选择方法。
8. **公证机制**。通过第三方机构，实现对通信数据的完整性、原发性、时间和目的地等内容的公证。一般通过数字签名、加密等机制来适应公证机构提供的公证服务。

2. 网络空间安全体系框架

管理体系管理是信息系统安全的灵魂。

信息系统安全的管理体系由法律管理、制度管理和培训管理三个部分组成。

三分技术，七分管理；(×) 应该是：管理与技术并重。

3. 密码模型

3.1 加密过程

3.2 鉴别过程

3.3 消息鉴别码

3.3.1 技术实现基本思路

3.4 基于RSA的数字签名

CH5 鉴别机制与技术

1. 对身份鉴别系统的要求

1. 验证者正确识别合法申请者的概率极大化。
2. 不具有可传递性 (Transferability)

3. 攻击者伪装成申请者欺骗验证者成功的概率要小到可以忽略的程度
4. 计算有效性
5. 通信有效性
6. 秘密参数能安全存储

2. 鉴别技术分类：按保护等级分类

0 级鉴别（无保护）

1 级鉴别（抗泄露保护）

2 级鉴别（抗泄露和对不同验证者重放的保护）

3 级鉴别（抗泄露和对同一验证者重放的保护）

申请者向验证者发送：

1. 鉴别请求
2. 可辨别标识符
3. 惟一编号
4. F(申请AI, 惟一数, 可辨别标识符, 数字指纹)

鉴别请求: 告诉服务器“我要开始验证身份了”。

可辨别标识符 (Distinguished Identifier): 申请者的账号或 ID，让验证者知道是谁在请求。

AI: Authentication Information 鉴别信息

[惟一编号] / 惟一数 (Nonce): 这是防重放攻击的核心。这是一个随机数或序列号，确保这条信息是“新鲜”的。即使黑客截获了这条信息，因为这个数字下次就变了，黑客也无法通过重复发送同一条信息来冒充你。

[数字指纹] (Digital Fingerprint): 通常指消息认证码 (MAC) 或数字签名，用来证明这串数据确实是由申请者本人发出的，且中途没有被篡改。

F是一个类似于hash的函数

惟一数来源：

1. 随机数或伪随机数：在申请AI的生命期内，不可有意重复。
2. 时间戳：从可信来源得到，在申请AI的生命期内，惟一性。
3. 计数器：惟一数是计数器的值。
4. 密码链：由（密码）分组链在申请者与验证者之间先前交换的数据内容导出。

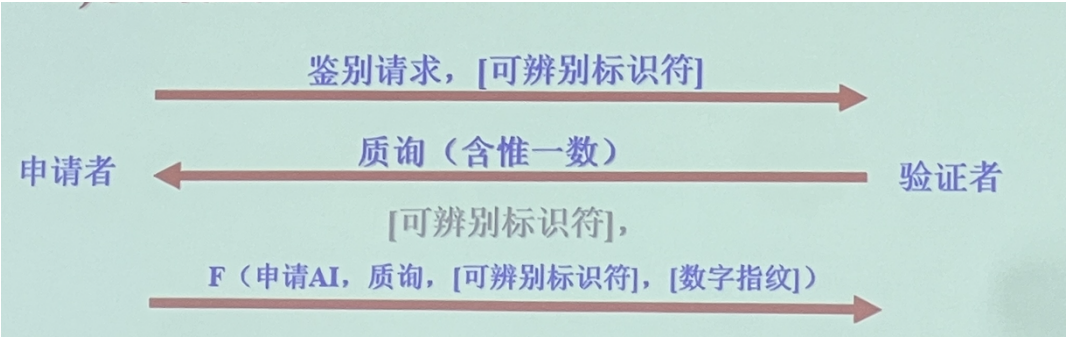
4 级鉴别（抗泄露和对相同 / 不同验证者重放的保护）

四种实现方案：4A)惟一数机制，4B)质询机制，。。。

惟一数机制

- 1. 申请者向验证者发送：
- 2. 鉴别请求
- 3. 可辨别标识符
- 4. 惟一编号
- 5. $F(\text{申请AI}, \text{惟一数}, \text{验证者}, \text{可辨别标识符}, \text{数字指纹})$

质询机制



对抗重放攻击。

验证者以带有惟一值的数据项形式对申请者发出质询，申请者利用某个函数对质询信息和申请 AI 进行变换，且向验证者返回变换结果。

可应用于数据源和实体鉴别

3. 鉴别机制/非密码鉴别机制

3.1 基于口令的身份鉴别

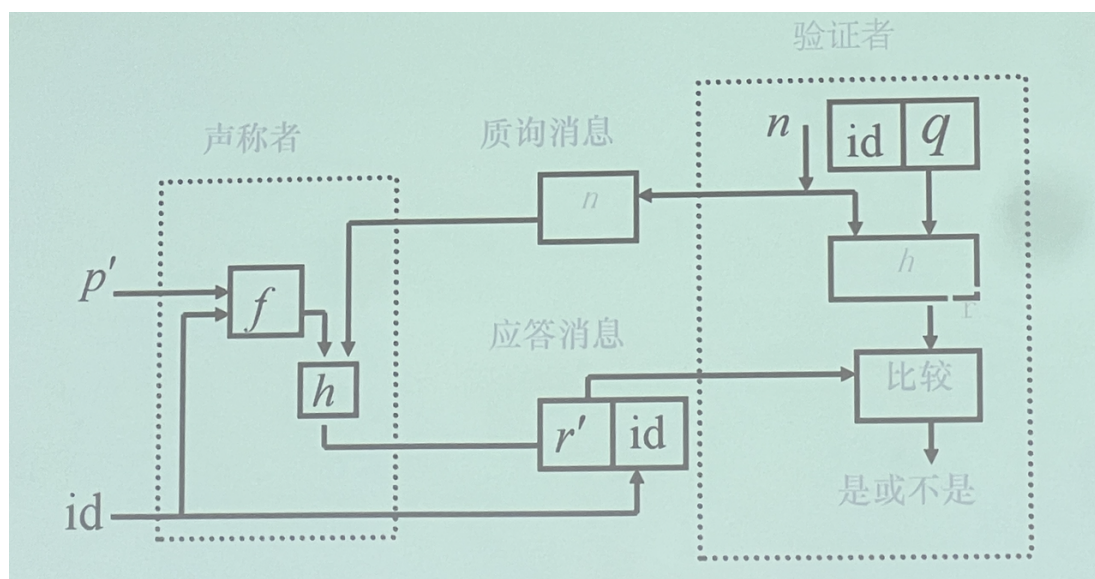
3.1.1 基于质询-应答的身份鉴别机制

基于质询 — 应答的身份鉴别在鉴别时：

由验证者给声称者发送一个确定的值（质询消息），该值参与鉴别信息的运算。

产生的非重复质询消息完全由验证者决定，使得每次传输的鉴别信息不同。

这能很好地防止口令窃听和重放，但需要额外的通信花销。



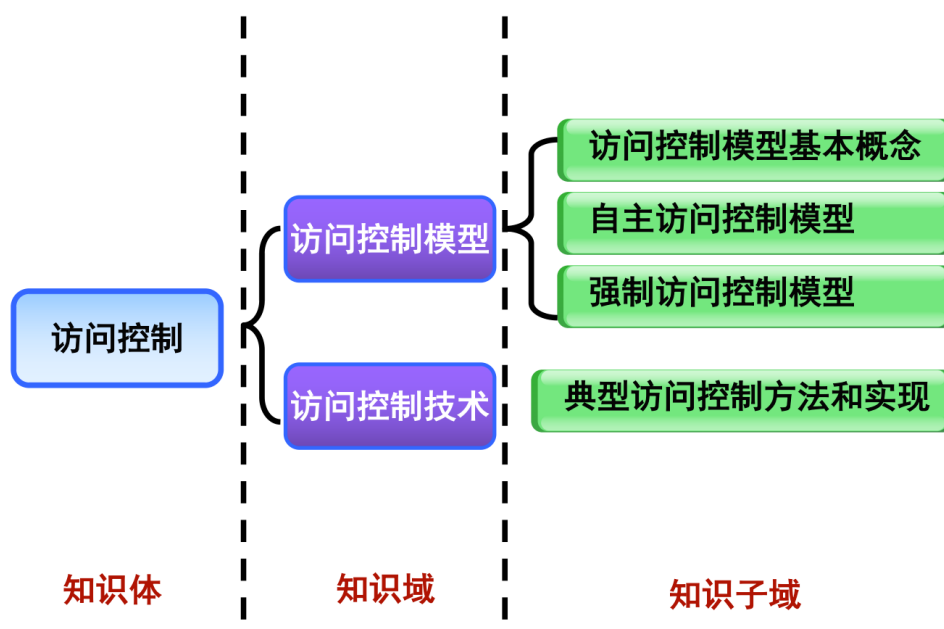
3.2 基于生物特征的身份鉴别

基于假设：每个人的生理特征（视网膜，声音，虹膜、语音、面部、签名等）所具有唯一性指纹

3.3 基于个人令牌的身份鉴别

3.4 Kerberos 身份鉴别协议

CH6 访问控制机制与技术



1. 访问控制的相关概念

1.1 访问控制的概念：

针对越权或未授权使用资源的防御措施

1.2 目标：

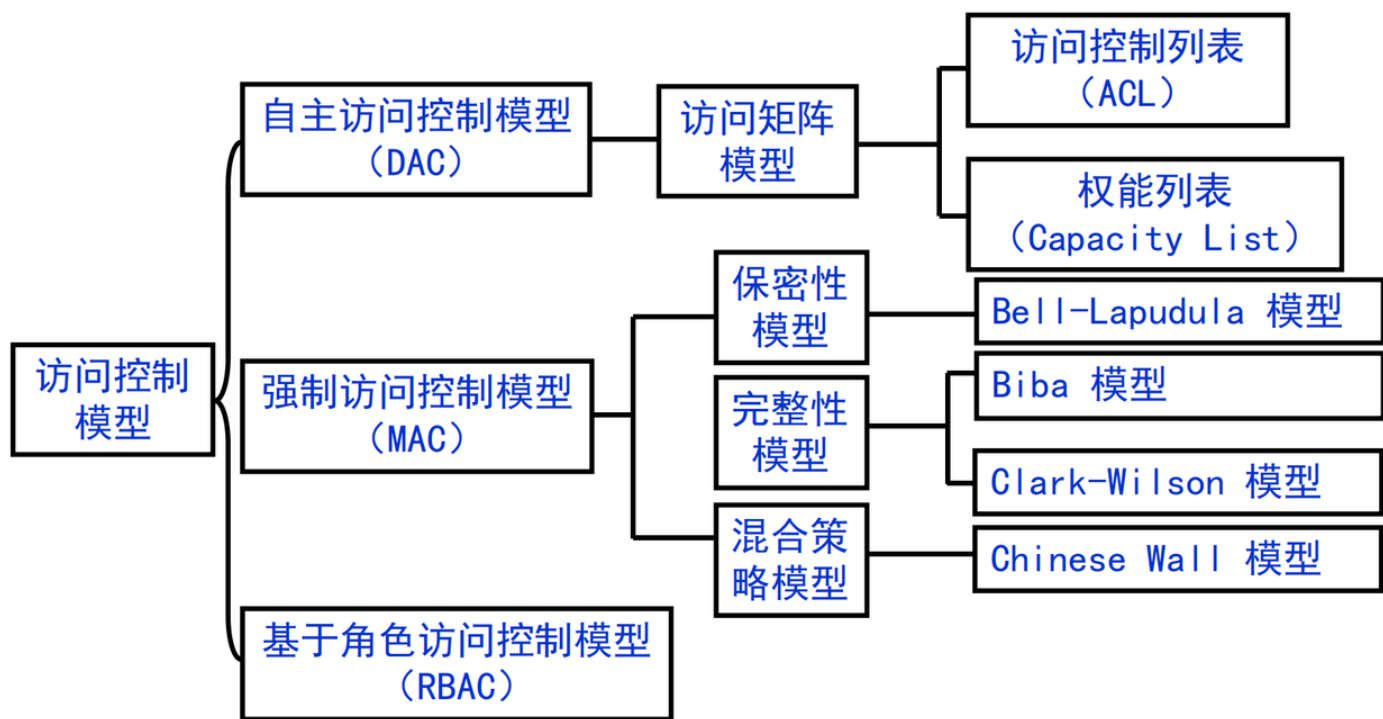
防止对任何资源（如计算资源、通信资源或信息资源）进行未授权的访问，从而使资源在授权范围内使用，决定用户能做什么，也决定代表一定用户利益的程序能做什么。（最小授权原则）

1.3 两个重要过程

- 第一步：鉴别
 - 检验主体的合法身份
- 第二步：授权
 - 限制用户对资源的访问权限

2. 访问控制模型

2.1 分类



主体是系统中**主动**请求访问资源的实体。客体是系统中**被动**接受访问的资源或实体。

主体访问客体

2.2 自主访问控制（DAC）

概念

允许客体的属主（创建者）决定主体对该客体的访问权限，是一种分布式授权管理的模式

描述（选择题）：

- 灵活地调整安全策略
- 具有较好的易用性和可扩展性
- 常用于商业系统
- 安全性不高

特点

优点

- 根据主体的身份和访问权限进行决策
- 具有某种访问能力的主体能够自主地将访问权的某个子集授予其它主体
- 灵活性高，被大量采用

缺点

- 信息在传递过程中其访问权限关系会被改变

2.3 强制访问控制（MAC）

2.3.1 概念

主体对客体的所有访问请求按照**强制访问控制策略**进行控制，**客体的属主无权控制客体的访问权限**，以防止对信息的非法和越权访问。

描述（选择题）：

- 主体和客体分配有一个安全属性
- 应用于军事等安全要求较高的系统
- 可与自主访问控制结合使用

2.3.2 特点

- 将主体和客体分级，根据主体和客体的级别标记来决定访问模式。
- 其访问控制关系分为：**上读/下写，下读/上写**。
- 通过梯度安全标签实现单向信息流通模式。

2.3.3 四种强制访问控制策略规定（基本操作权限）：

1. **下读**：用户级别大于文件级别的读操作；

允许高等级的人看低等级的文件。

2. **上写**：用户级别低于文件级别的写操作；

允许低等级的人向高等级的文件中添加信息，但禁止高等级人员向低等级文件写信息。

防止高层秘密流向低层。

3. 下写：用户级别大于文件级别的写操作；

只有高级别人员才能修改低级别文件，低级别人员严禁向高完整性（数据极度可信）文件写入。

4. 上读：用户级别低于文件级别的读操作；

高完整性的人不读低完整性的劣质数据。防止“高价值的决策或数据被劣质信息污染”

举例：

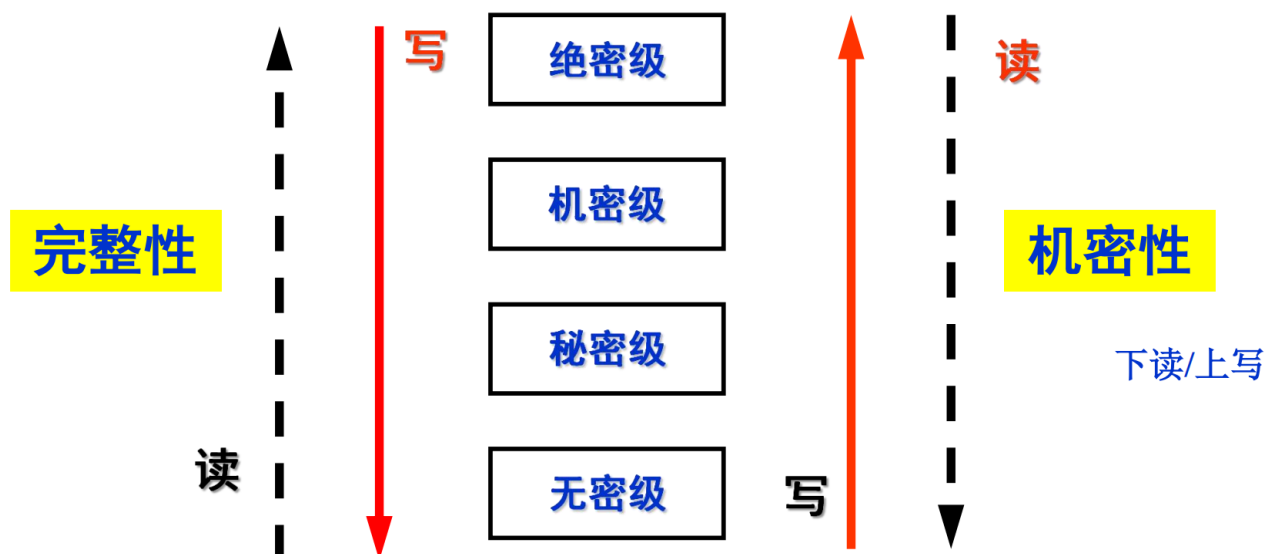
假设你是一个自动驾驶系统的控制核心（高完整性主体）。

低完整性数据：一个黑客通过传感器发送了虚假的障碍物信号（低完整性数据）。

后果：如果你（高完整性主体）读取了这个假信号，你就会做出“紧急刹车”的指令。

下读/上写分为一组，上读/下写分为一组，分别为机密性和完整性

写代表了信息流动的方向

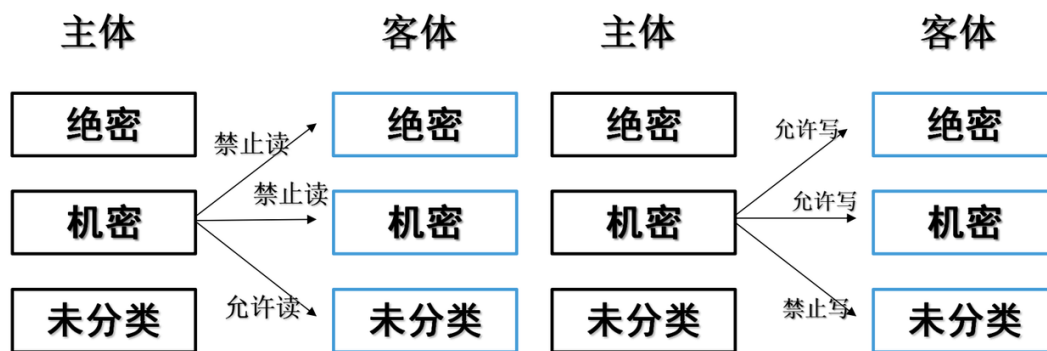


2.3.4 常见的MAC模型——BLP模型

下读 + 上写 = 保护机密性 (BLP模型)

❖ 下读/上写（下读/不下写）

❖ 保证机密性



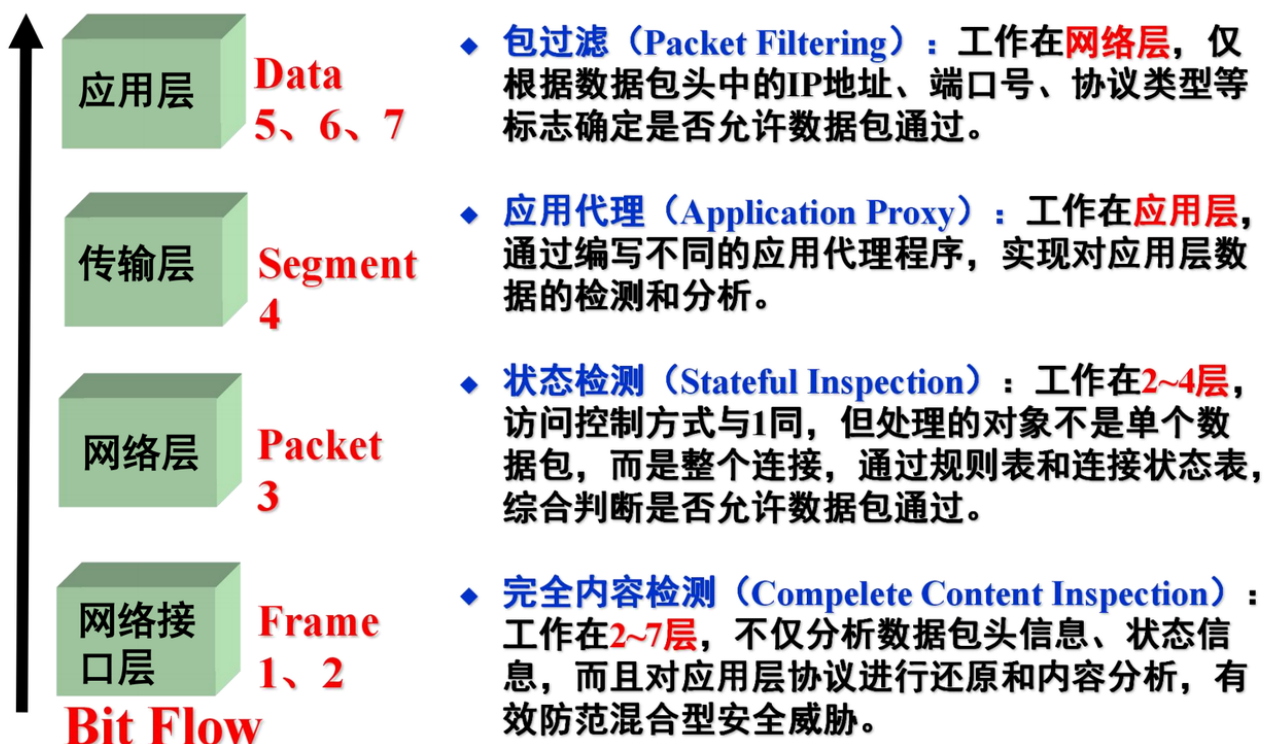
CH7 防火墙技术及其发展

1. 防火墙的基本概念

1.1 定义

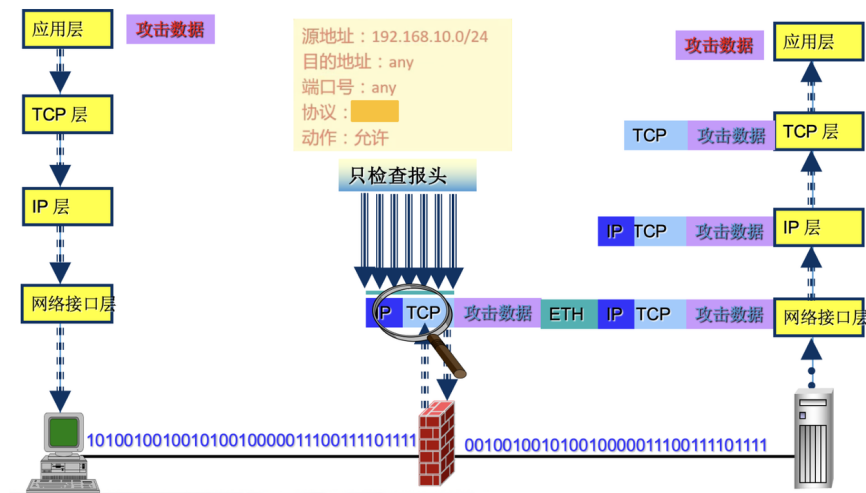
在网络间（内部 / 外部网络、不同信息级别）提供安全连接的设备，用于实现和执行网络之间通信的安全策略。

2. 防火墙的相关技术（四种）



2.1 包过滤防火墙工作原理

1. 简单包过滤防火墙只检查数据包的包头信息，不检查数据区
2. 简单包过滤防火墙不建立连接状态表
3. 前后报文无关
4. 应用层控制很弱

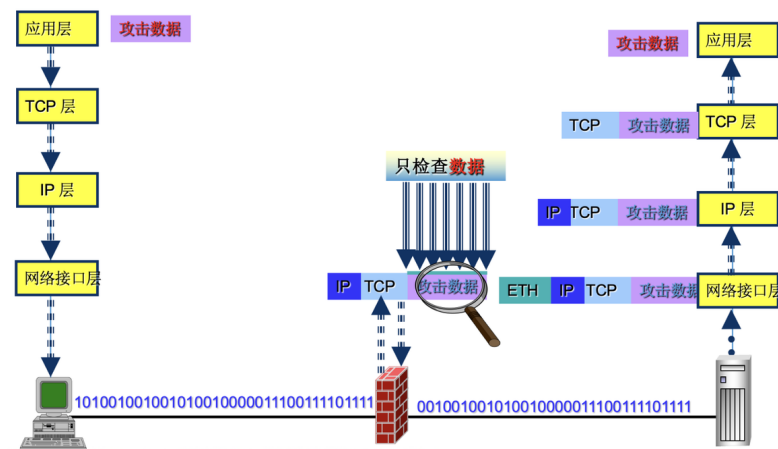


2.2 应用代理防火墙工作原理

不检查IP、TCP报头，只查数据

不建立连接状态表

网络层保护比较弱



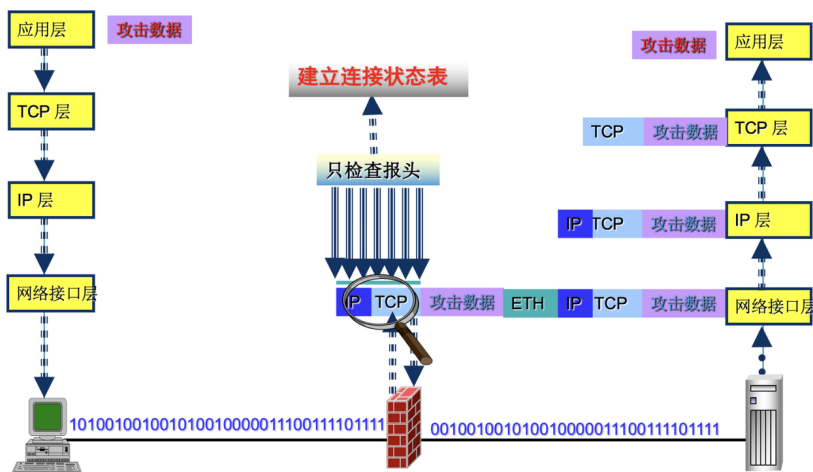
2.3 状态监测防火墙工作原理

不检查数据区

建立连接状态表

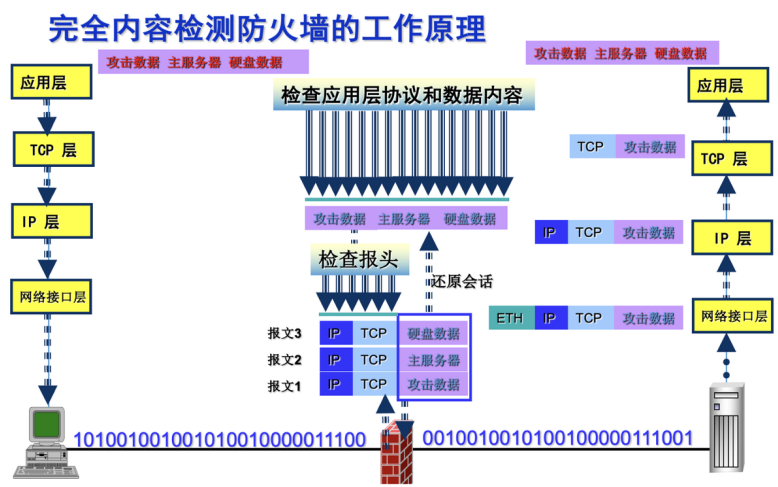
前后报文相关

应用层控制很弱



2.4 完全内容检测防火墙的工作原理

- 网络层保护强
- 应用层保护强
- 会话保护很强
- 上下文相关
- 前后报文有联系



3. 防火墙的功能——地址转换（NAT）

地址转换的整个过程

实例：

内网主机（私有 IP，如 192.168.1.10）发起对互联网（8.8.8.8）的请求时

查找路由：防火墙首先检查路由表，确定该数据包应该从哪个接口发出（通常是连接外网的 WAN 口）。

安全策略匹配：防火墙检查访问控制列表（ACL）。如果策略拒绝该流量，包会被直接丢弃；如果允许，则进入下一步。

源地址替换：防火墙将数据包头部中的**私有源 IP** 替换为**公网出口 IP**。

端口映射 (PAT)：如果是多台设备共享一个公网 IP，防火墙还会修改**源端口**（Source Port），确保每个连接在公网上都是唯一的。

状态记录：防火墙会在内存中生成一条 **NAT 会话表项**（Session Entry），记录：

[内网 IP : 内网端口] <---> [公网 IP : 转换后端口] <---> [目标 IP : 目标端口]

当目标服务器回传数据时，防火墙会执行反向操作

特点

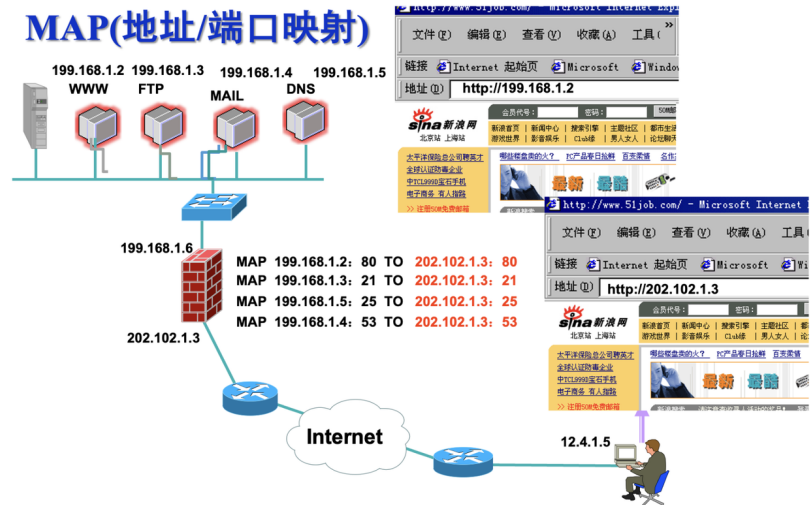
- 隐藏了内部网络的结构
- 内部网络可以使用私有IP地址
- 公开地址不足的网络可以使用这种方式提供IP复用功能

4. 防火墙的功能——地址/端口映射（MAP）

特点

- 公开服务器可以使用私有地址
- 通过防火墙映射到公网ip即可
- 隐藏内部网络的结构

图中，用户通过访问公网ip即可访问到内部的服务器

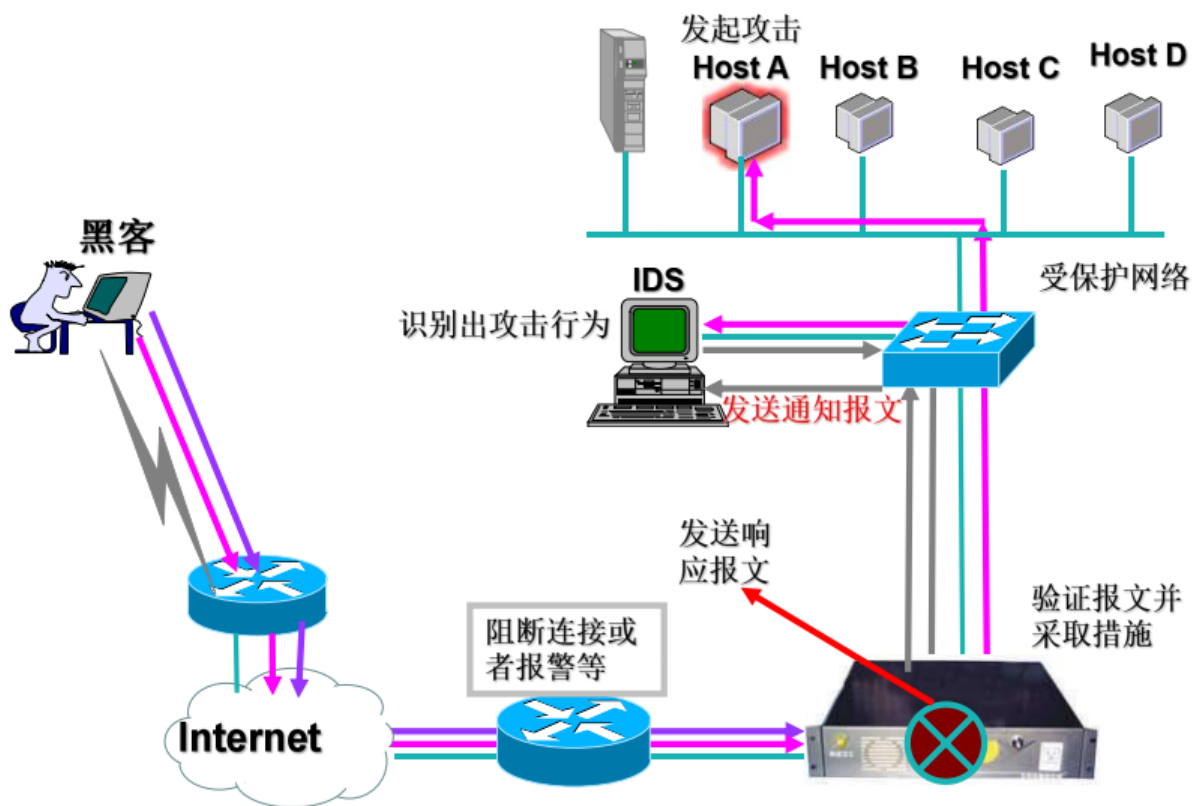


MAP与NAT什么区别

如果是 SNAT（普通上网）：防火墙只需要“会话表”。因为是你先求偶，回包是顺着原路回来的，会话表能搞定。

如果是 FTP 这种“怪胎”：服务器会主动连接客户端的一个随机端口。这时候客户端根本没发包，防火墙里没会话，包会被挡住。MAP 的存在就是为了告诉防火墙：“等下服务器会开个新门连过来，请直接给它开张票，别拦着它。”

5. 防火墙的功能——访问控制与IDS的安全联动



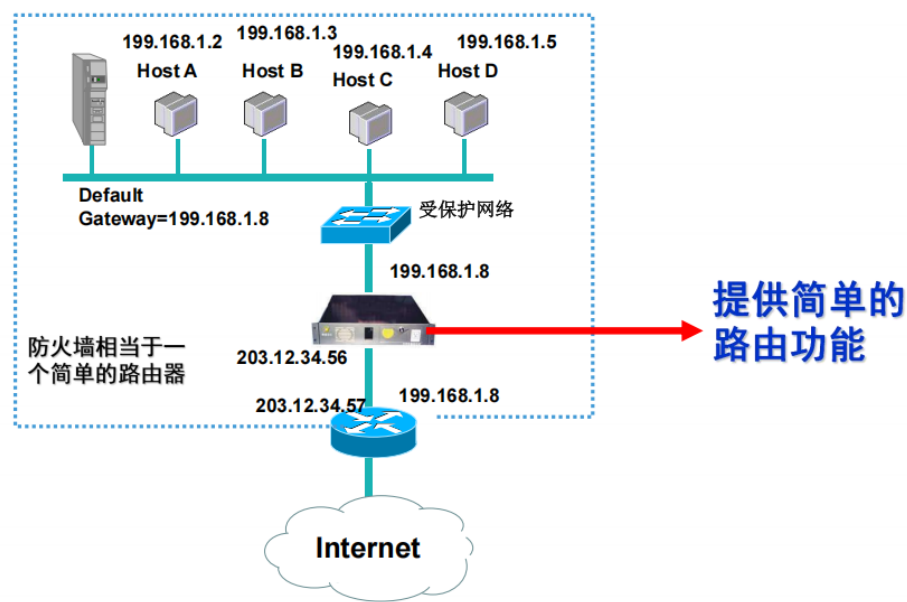
流程：黑客向HostA发送恶意流量包，流经交换机时会被IDS复制一份拿去分析

IDS分析发现存在攻击行为，但它并没有权限阻止，于是向访问控制设备（防火墙）发送通知报文，由防火墙验证报文并采取措施，然后向控制中心发送响应报文。

6. 防火墙的工作接入方式

6.1 路由接入工作模式

负责跨网段安检。

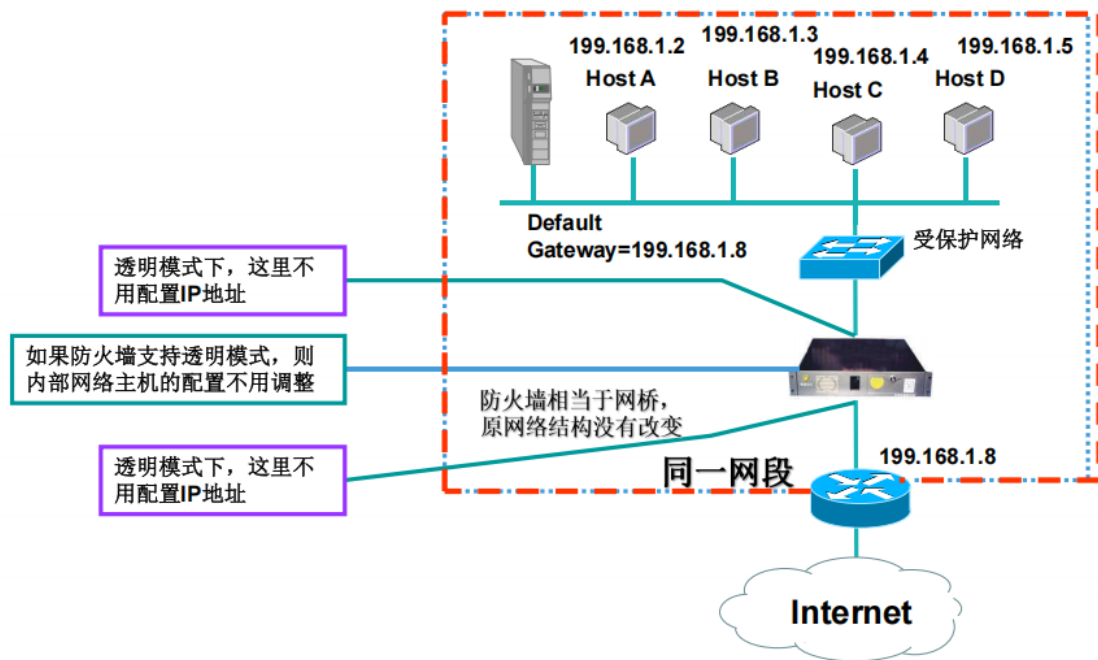


防火墙表现得像一台**路由器**。

它分割广播域，每个接口有独立的 IP，负责不同网段间的地址转换（MAP/NAT）。

6.2 透明接入方式

在传统的网络中，同一网段内的设备通过交换机直接通信，流量是不经过网关路由器的。还需要一个插在交换机中间的安检。



防火墙表现得像一个网桥。

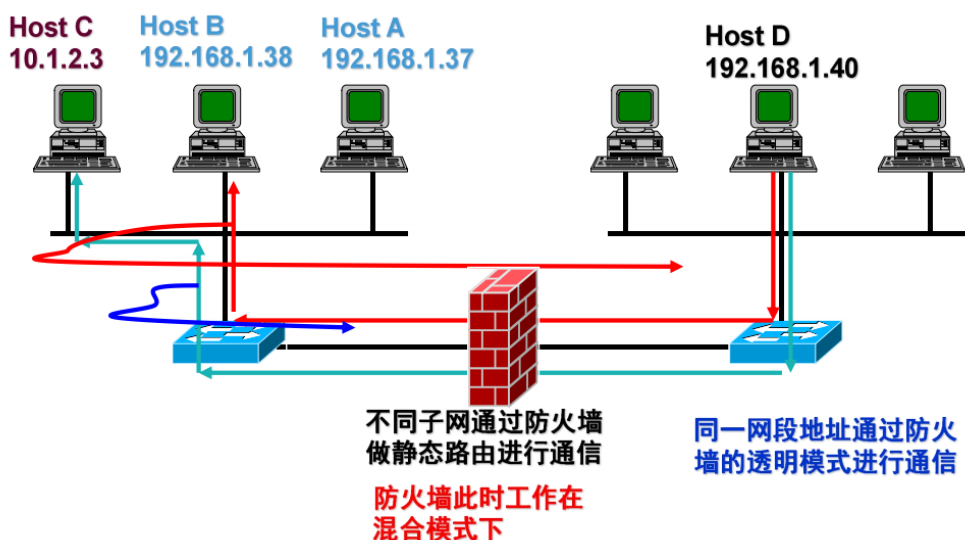
它不改变 IP 布局，接口没有 IP。它的存在对网络层是“隐形”的，只负责在同一网段内做安全过滤。

6.3 混合接入方式

工作于透明接入模式的防火墙可以实现透明接入。

工作于路由模式的防火墙可以实现不同网段的连接。

路由接入和透明接入是针对不同领域的



防火墙同时具备路由器和网桥的功能。

某些接口成对配置为“网桥”进行同网段过滤，另一些接口配置 IP 参与路由和地址转换。

7. 衡量防火墙性能的五大指标

7.1 吞吐量：

定义：在不丢包的情况下能够达到的最大速率。

衡量指标：吞吐量越大，防火墙性能越高。

该指标直接影响网络的性能，如果吞吐量小，防火墙就会称为网络的瓶颈。

测试：以逐步增大的速率发包，直到出现丢包时速率的最大值。

7.2 时延：

入口处输入帧最后1个比特到达至出口处输出帧的第1个比特输出所用的时间间隔

7.3 丢包率：

在稳态负载下，应由网络设备传输，但由于资源缺乏而被丢弃的帧的百分比

7.4 背靠背：

定义：从空闲状态开始，以达到传输介质最小合法间隔极限的传输速率发送相当数量的固定长度的帧，当出现第一个帧丢失时，**发送的帧数**。

最小合法间隔极限的传输速率，就是最大速率，满带宽

衡量标准：背对背包主要是指防火墙缓冲容量的大小。网络上经常有一些应用会产生大量的突发数据包（例如：NFS，备份，路由更新等），而且这样数据包的丢失可能会产生更多的数据包的丢失，强大缓冲能力可以减小这种突发对网络造成的影响。

背靠背是体现防火墙对突发数据的处理能力。

7.5 并发连接数：

并发连接数是指穿越防火墙的主机之间或主机与防火墙之间能同时建立的最大连接数

CH8 入侵检测技术

1. 入侵检测的相关概念

1.1 入侵的定义

入侵（Intrusion）是指在非法或未经授权的情况下，试图存取或处理系统或网络中的信息，或破坏系统或网络正常运行，致使系统或网络的机密性、完整性和可用性受到破坏的故意行为。

1.2 入侵检测的定义

入侵检测（Intrusion Detection）是对入侵行为的发觉。它通过计算机网络或计算机系统的关键点采集信息并进行分析，从中发现网络或系统中是否有违反安全策略的行为和被攻击的迹象。

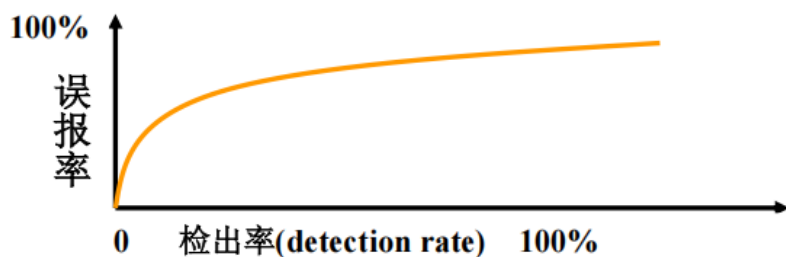
1.3 入侵检测系统

定义

入侵检测系统（Intrusion Detection System，简称 IDS）是指实现入侵检测功能的软件和硬件的集合。

两个指标

- 漏报率(false negative)
 - 指攻击事件没有被IDS检测到
- 误报率(false alarm rate)
 - 把正常事件识别为攻击并报警
 - 误报率与检出率成**正比例**关系



分类

按检测分析技术方法

1.3.1 异常检测

通过采集和统计来发现网络或系统中可能出现的异常行为，向管理员提出警告。

之后一旦出现 “和正常不一样的行为” 就报警

描述：

- 也称为基于**行为**的检测

- 首先建立起用户的正常使用模式，即知识库
- 标识出不符合正常模式的行为活动
- 假设所有的入侵行为是异常的
- 基于系统和基于用户的异常
- 比较符合安全的概念，但是实现难度较大
 - 正常模式的知识库难以建立
 - 难以明确划分正常模式和异常模式

1.3.2 特征检测

通过对采集的信息按已知的知识进行分析，来发现正在发生和已经发生的入侵行为。

一旦发现事先保存的“攻击特征”，就报警。

描述：

- 也称为**误用**检测
- 是针对已知（类似）的攻击行为和间接的违背系统安全策略行为的检测，攻击和系统漏洞库是特征检测的基础。
- 建立入侵行为模型(攻击特征库)
- 判别当前行为活动是否符合已知的攻击模式
- 假设可以识别和表示所有可能的特征
- 基于系统的和基于用户
- 目前研究工作比较多，并且已经进入实用

优点：

- 准确率高
- 算法简单

关键问题：

- 有所有的攻击特征，建立完备的特征库
- 特征库要不断更新（动态性）
- 无法检测新的入侵

数据来源

- 审计日志或网络流量
- 特殊用途的数据收集机制

使用的检测方法

- 基于专家系统的检测技术
根据安全专家对可疑行为的分析经验来形成一套推理规则，然后再在此基础之上构成相应的专家系统，并应用于入侵检测。基于规则的专家系统或推荐系统的也有一定的局限性。
- 基于简单规则的模式匹配技术
- 基于攻击签名分析的检测技术
把获得的攻击知识翻译成可在系统审计轨迹中直接发现的信息，在检测时不需要语义级的攻击描述
- 基于统计模式匹配的检测技术
把系统审计轨迹视为抽象事件流，使用 CPN 来描述攻击者的攻击模式、入侵检测器作用模式匹配器
- 基于状态转换分析的检测技术
考虑攻击行为对每步系统状态转移的影响，可检测协同攻击和利用用户会话的攻击行为

分析策略	特征检测	异常检测
缺省即允许	基于信号的特征检测	基于机器学习的异常检测
缺省即禁止	基于策略的特征检测	基于轮廓的异常检测

缺省即允许：默认没问题，缺省即禁止：默认有问题

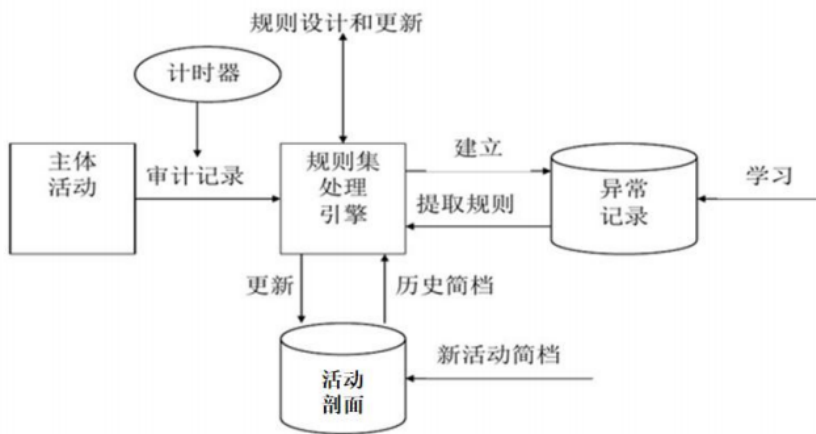
按检测范围

- 基于主机
- 基于网络
- 基于网络节点

2. 入侵检测模型

2.1 通用入侵检测模型（Denning模型）

实质是一个基于规则的模式匹配系统

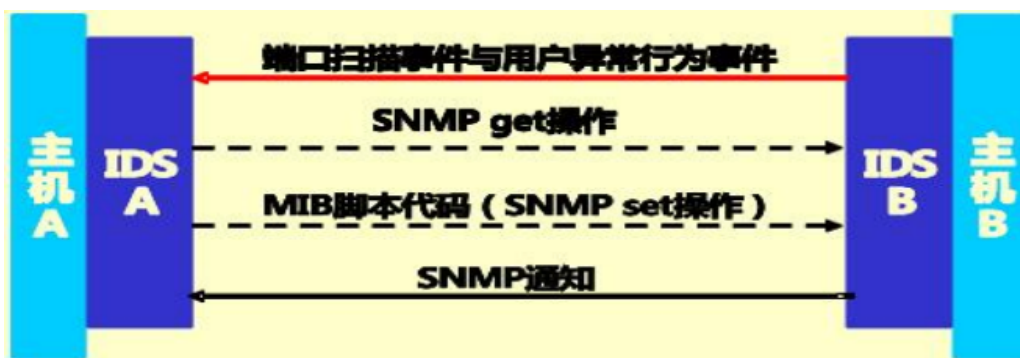


2.2 层次化入侵检测模型 (IDM)

2.3 管理式入侵检测模型 (SNMP-IDSM)



工作原理：



IDS B：监视主机 B、请求最新 IDS 事件

IDS A 观察到一个来自主机 B 的攻击企图：

IDS A 与 IDS B 联系；

IDS B 响应 IDS A 的请求；

IDS B 发布异常活动事件；

IDS A 观察到一个来自主机 B 的攻击企图：

IDS A 使用 MIB 脚本发送代码给 IDS B，用于收集主机 B 的网络活动和用户活动信息；

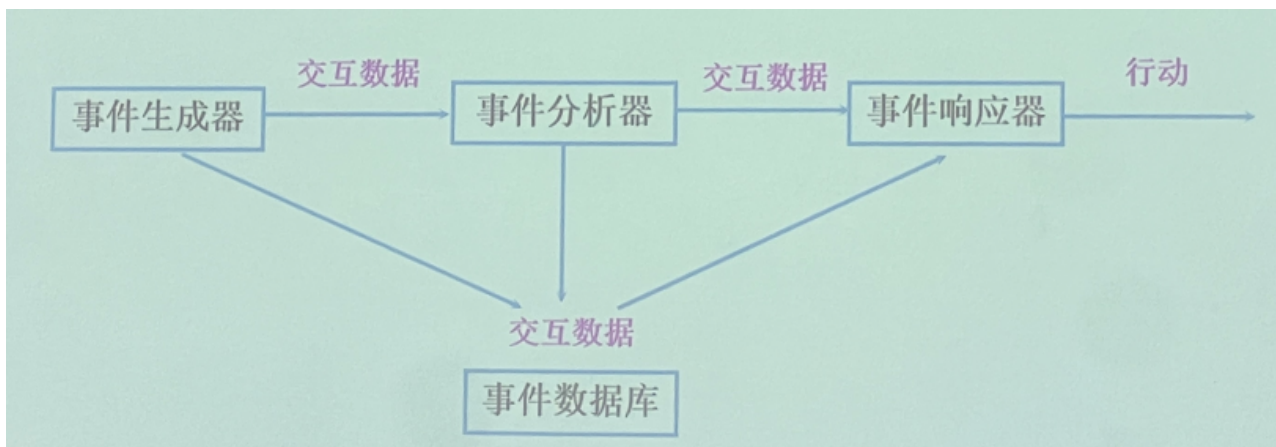
IDS A 根据所收集的信息进行入侵分析。

管理式入侵检测就是有一个“监控中心主管”（IDS A），当他怀疑某个区域有问题时，可以远程命令那里的保安（IDS B）“带上专业设备去查一下那个人的身份证并翻一下他的包”，并将结果带回来。

但其实是对称的，谁被攻击谁是大哥

2.4 上述三种入侵检测模型的通用模型（CIDF）

组成：事件生成器，事件分析器，事件响应器，事件数据库



事件生成器：搜集被保护的信息，作为事件存在数据库中。

事件分析器：区分事件的危险与否（定期分析数据库中保存的数据，以及某段时间出现的异常数据）

事件响应器：对异常数据作出反应

事件数据库：存储分析结果和事件

CH9 其他网络安全技术及设备

1. 入侵防御系统（IPS）

1.1 基础理念

旁路部署 + 深层分析 = 无法防御“无连接攻击”

在线部署 + 低层分析 = 无法防御“深层攻击”

因此深层防御需要**深层分析**和**在线部署**

而IPS兼具了上述两点，因此**IPS 是深层防御的最优方案**

1.2 概念

IPS是一种集入侵检测和防御于一体的安全产品，它不但能检测入侵的发生，而且能通过一定的响应方式，实时地中止入侵行为的发生和发展，实时地保护信息系统不受实质性的攻击。IPS使得IDS和防火墙走向统一。简单地理解，可认为IPS就是**防火墙加上入侵检测系统**。

1.3 功能

- 识别对网络和主机的恶意攻击，并实时进行阻断；
- 向管理控制台发送日志信息；
- 集成病毒过滤、带宽管理和URL过滤等功能；

1.4 IPS与IDS

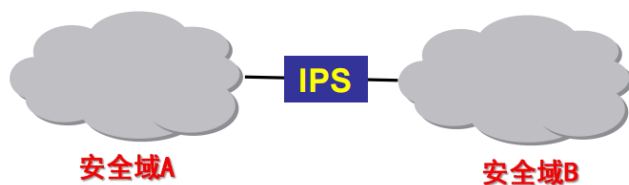
部署方式对比

IPS	IDS
在线, 流量必须通过IPS	旁路, 通过镜像获得数据
实时, 其时延必须满足业务要求	准实时, 可接受秒级时延
立刻影响网络报文	对网络及业务无直接影响
作用范围有限制	监控范围广

设计出发点对比

IPS	IDS
无误报，但有漏报（0 day）	无漏报
满足峰值流量和时延要求	满足平均流量, 可接受秒级时延
不能影响业务系统可用性	只需关注自身功能实现

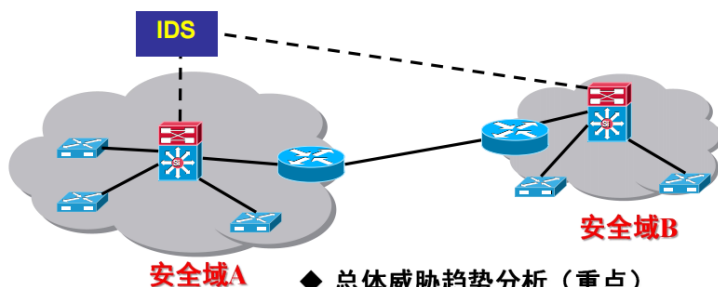
1.5 IPS能够解决的安全问题



- ◆ 阻拦已知攻击（重点）
- ◆ 为已知漏洞提供虚拟补丁（重点）
- ◆ 速率或流量控制
- ◆ 行为管理

IPS可提供有效的、防火墙无法提供的应用层安全防护功能。
但为了避免误报，IPS对未知攻击的防御能力几乎没有

IDS能够解决的安全问题



- ◆ 总体威胁趋势分析（重点）
- ◆ 流量及连接分析（重点）
- ◆ 安全事件分析（重点）

- IDS从总体和趋势上的分析能力是其他安全设备难以实现的
- 通过基于流量、统计等方面的分析，IDS理论上可防御未知攻击
- 攻击特别是蠕虫类攻击爆发时进行预警的能力

2. 安全隔离与信息交换系统（网闸）

2.1 产生背景

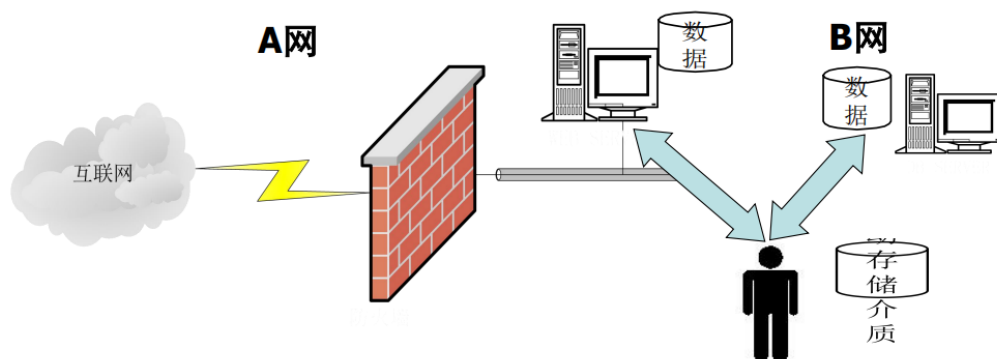
2.1.1 应对网络安全漏洞传统解决方案——物理隔离

- 中共中央办公厅第十七号文件规定 “电子政务网络由政务内网和政务外网构成，两网之间**物理隔离**，政务外网与互联网之间逻辑隔离。”
- 国家保密局制定的《计算机信息系统国际联网保密管理规定》中第六条规定：“涉及国家秘密的计算机信息系统，不得直接或间接地与国际互联网或其他公共信息相连接，必须实行**物理隔离**”。
- 一些组织根据自身业务的特点，在有不同安全需求的网络之间也采取了**物理隔离**的措施。

物理隔离的核心思想是**不连接，没有连接！！**

2.1.2 传统物理隔离的应用解决方案

人工拷盘



优点

保持了网络间物理隔离的特性，有效防止了对涉密网络的直接网络攻击

缺点

延时长、速度慢、能够满足的应用过于单一、可靠性低、在防病毒、内容过滤等方面效果较差、人工操作风险高。

2.2 什么是网闸

定义

网闸是在两个不同安全域之间，通过（特殊的通讯）协议转换的手段，以信息摆渡的方式实现数据交换，且只有被系统明确要求传输的信息才可以通过。其信息流一般为通用应用服务。

信息摆渡（运输）： 中间的隔离单元像一艘摆渡船，通过非网络协议的私有总线（如特殊的电子开关）将纯数据从外端机搬运到内端机。

协议剥离（卸货）： 当数据从外网进入时，外端机会把所有的通用网络协议（如 TCP/IP, HTTP, FTP）全部“剥掉”。
协议封装（重新装箱）： 内端机接收到纯数据后，根据内网的要求，重新封装成内网协议。

说明

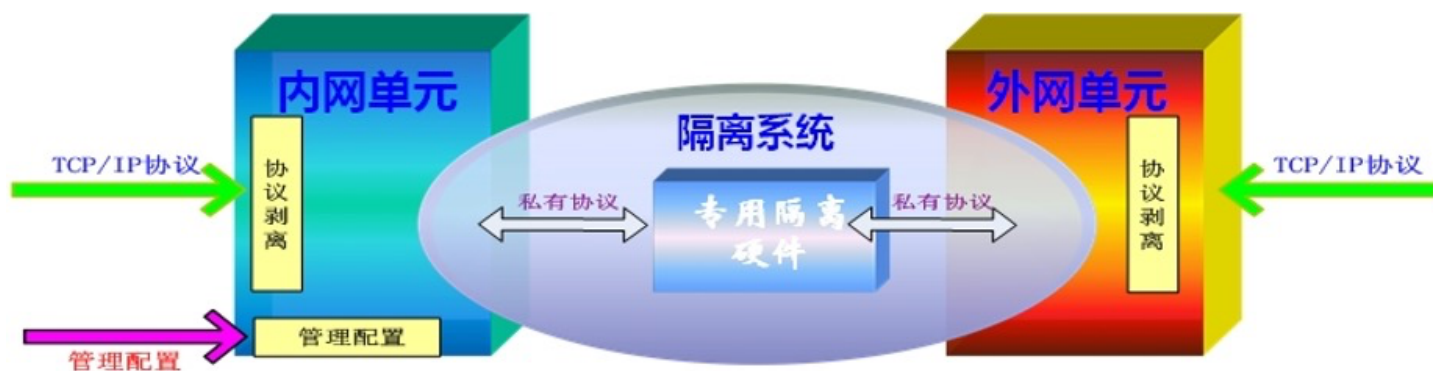
在信息摆渡的过程中内外网（上下游）通过策略控制连接发生，所以“网闸产品”必须要有至少两套主机和一个隔离部件才可完成物理隔离任务。

用途

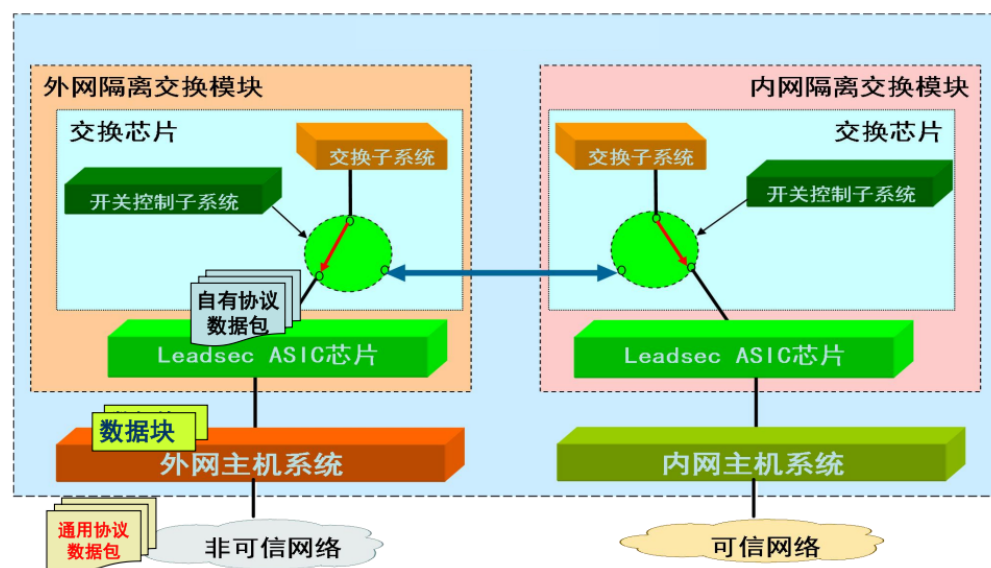
网闸主要用于在两个隔离程度高的网络之间进行安全的数据交换。

2.3 安全隔离网闸的组成

内端机，外端机，隔离系统（数据迁移控制单元）



2.4 网闸的运作原理（数据隔离与交换过程）



通用协议数据包->数据块->私有协议数据包->数据块->通用协议数据包

2.4.1 协议剥离

切断网络之间的通用协议连接；

将数据包进行分解或重组为静态数据；(数据块)

2.4.2 安全检查

对静态数据进行安全审查，包括网络协议检查和代码扫描等；

确认后的安全数据开始流入（通过信息摆渡）内部单元。

2.4.3 信息摆渡

网闸内部的隔离交换单元先切断与内网的连接，接通外网

将数据块封装成私有协议包，在内部总线上搬运，然后切断与外网的连接，转而接通内网。

2.4.4 协议重建

当数据块通过摆渡，到达内网处理单元，内部单元把那个临时的“私有协议包”拆掉，还原成原始数据块，再封装成通用协议包传给内网。

2.5 安全隔离网闸产品定位

- 安全隔离网闸的指导思想与防火墙有很大的不同：
 - 防火墙的思路是在保障互联互通的前提下，尽可能安全，
 - 安全隔离网闸的思路是在保证必须安全的前提下，尽可能互联互通。
- 安全隔离网闸的优势在于它通过在不可信网络牺牲自己来积极有效地应对攻击，以充分保护可信网络避免受到基于操作系统和网络的各种攻击。

所有的黑客扫描、拒绝服务攻击（DDoS）、漏洞利用（Exploit）都会直接打在外端机上。即使黑客利用系统漏洞彻底控制了外端机（即它被“牺牲”了），由于网闸内部存在物理断开的摆渡机制，黑客也无法以此为跳板直接渗透进内网。

3. 统一威胁管理系统（UTM）

3.1 UTM 定义

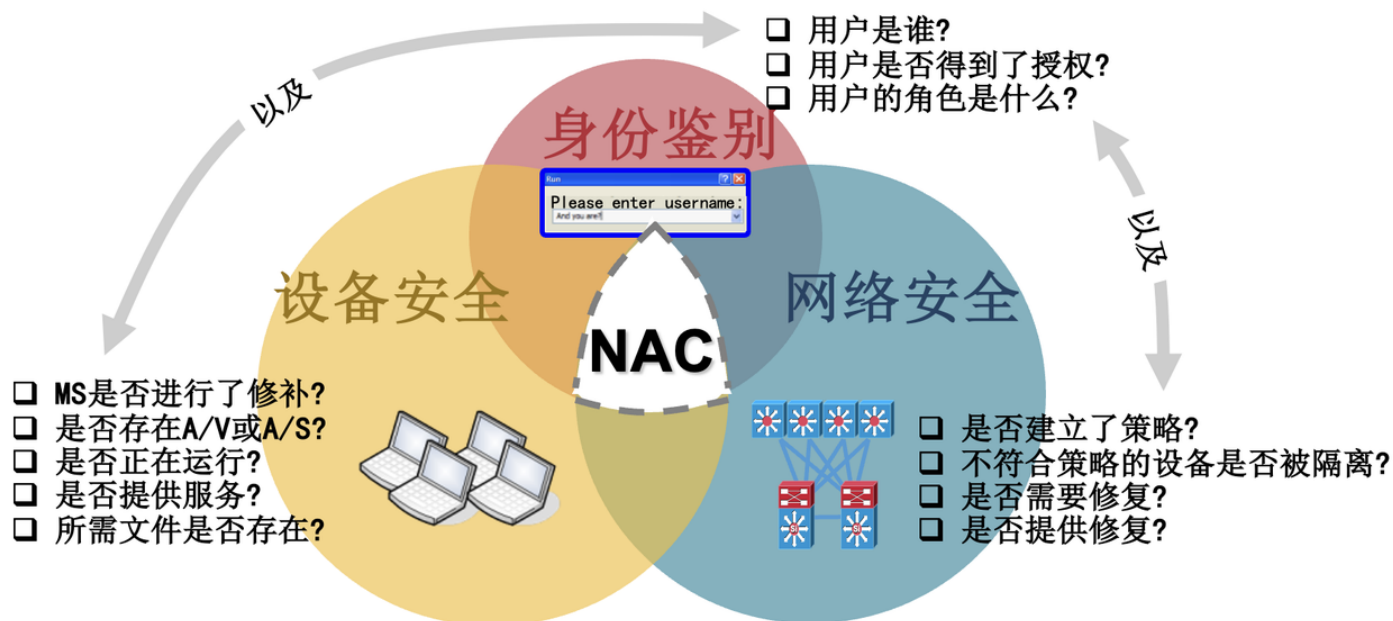
UTM（United Threat Management）意为统一威胁管理，是由硬件、软件和网络技术组成的具有专门用途的设备，它将多种安全特性集成于一个硬设备里，构成一个标准的统一安全平台。

由IDC(互联网数据中心于2004年提出)

4. 网络准入控制-NAC

4.1 什么是NAC

使用网络准入安全策略，确保进入网络的设备符合策略。

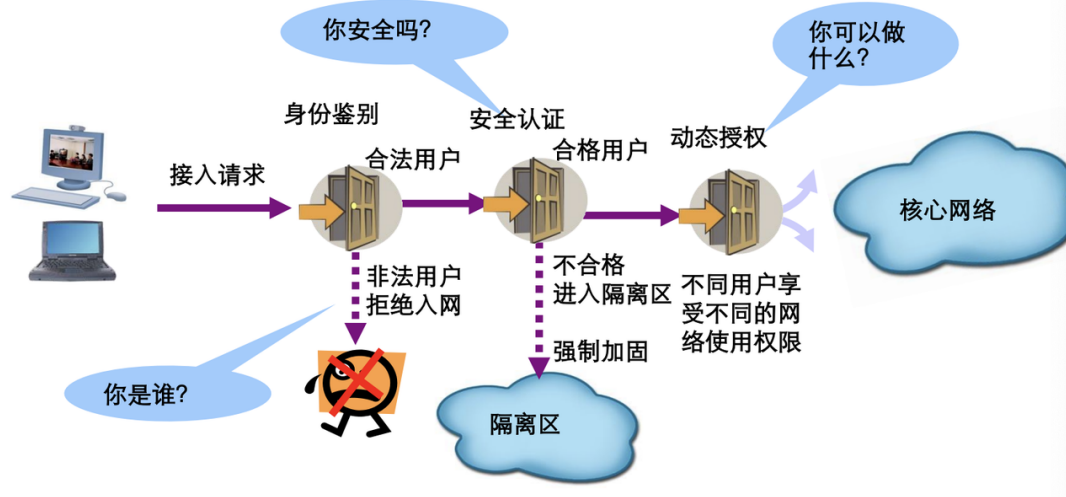


身份鉴别：你是谁？（员工、访客还是非法外来设备？）

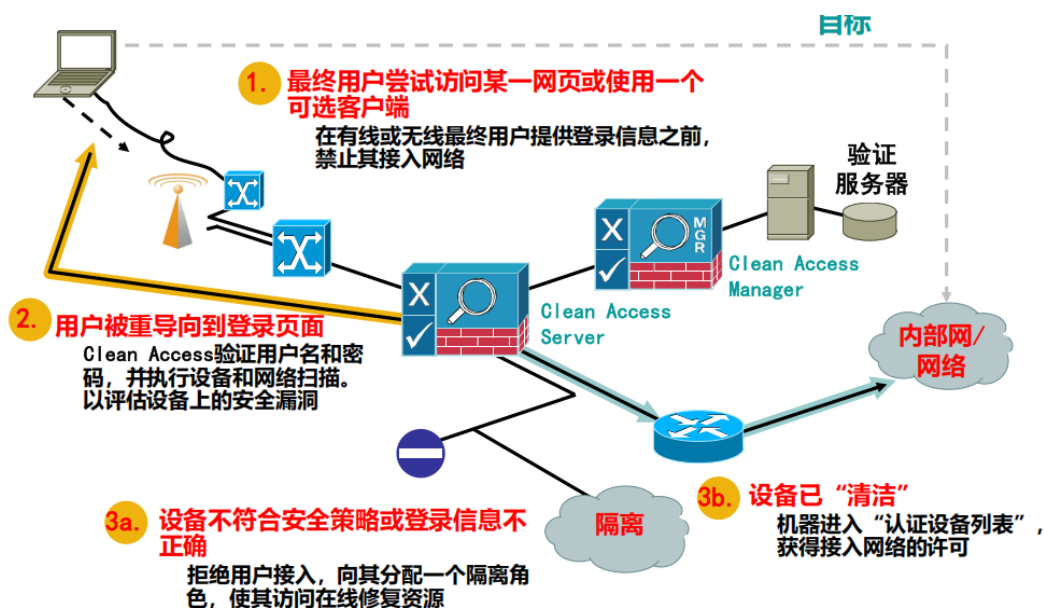
设备安全：你的设备安全吗？（有没有打补丁？有没有装杀毒软件？有没有开防火墙？）

网络安全：你能访问什么？（研发只能看代码仓库，财务只能看财务系统。）

4.2 网络准入控制系统的功能需求



4.3 用户流程



用户尝试访问网页。但在提供登录信息（身份证明）之前，中间的交换机或接入设备是禁止其接入网络的。

用户被重定向到一个登录页面。Clean Access Server验证用户名和密码，并执行设备和网络扫描

If: 设备不符合安全策略或登录错误

拒绝接入,但不是直接断开，而是把你分配到一个隔离角色,让你访问在线修复资源

Else： 机器被列入认证设备列表。

获得接入许可。此时，你的数据流可以越过 CAS，通过右侧的蓝色交换机，直接访问内部网/网络。

CH10 虚拟专用网技术

没有 VPN 时： 你寄出的快递（上网请求）是透明包装的，快递员（运营商/ISP）和路人都能看到包裹里是什么，也能清楚看到寄件人地址（你的真实 IP）。

使用 VPN 后：

- 1. 你的包裹被塞进了一个**防弹保险箱**（数据加密）。
- 2. 快递会先送到一个**中转站**（VPN 服务器）。
- 3. 从中转站发往目的地时，寄件人地址被改成了**中转站的地址**（隐藏真实 IP）。

1. VPN 的优点

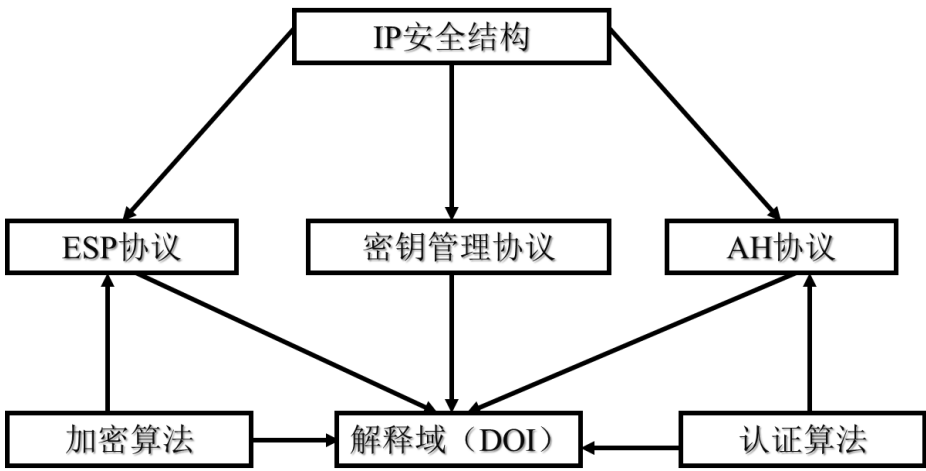
VPN 给企业带来的好处主要有以下四点：

- （1）降低成本 （2）易于扩展 （3）可随意与合作伙伴联网 （4）完全控制主动权

2. VPN的主要协议

2.1 IPSec协议

2.1.1 协议体系



IPsec 是框架： 它定义了安全通信的总流程。

在正式传输数据之前，双方先通过密钥管理协议（IKE）“握手”

再使用ESP/AH二选一进行数据传输

AH： 如果要求只签名不加密，就用 AH 封装。

ESP： 如果要求既签名又加密，就用 ESP 封装。

2.1.2 密钥协商协议(IKE)

IPsec采用IKE完成SA 的协商，IKE通过两个阶段的协商来完成SA的建立。它遵从了ISAKMP中给出的**两步式协商**，采用两阶段式协商完成SA的协商。

1. 第一阶段，由IKE交换的发起方发起的一个主模式（Main Mode）交换，交换的结果是建立一个名为ISAKMP SA的安全关联。这个安全关联的作用是保护安全协议协商SA的后续通信。

这一阶段的目标是建立一条安全的管理通道。双方在这个通道里进行身份认证和后续密钥的协商。

协商内容： 双方交换各自支持的加密算法（AES/3DES）、哈希算法（MD5/SHA）、认证方式（预共享密钥或数字证书）以及 DH 组。

2. 第二阶段，在ISAKMP SA的保护之下，可由通信的任何一方发起一个快捷模式（Quick Mode）的消息交换序列，完成用于保护通信数据的IPsec SA的协商。（这种模式必须在第一阶段运行后运行，它用于定义Diffie—Hellman专用组）

在第一阶段保护伞的遮蔽下，双方开始讨论真正的业务流量该如何加密。

协商内容： 协商具体的 IPsec 参数，包括：

使用哪种协议（AH 还是 ESP）？

使用哪种工作模式（传输模式 还是 隧道模式）？

具体的加密和鉴别算法。

2.1.3 IP鉴别头AH协议

如果把 VPN 比作私人隧道，AH 就是隧道里的一种**校验机制**

2.1.3.1 AH的功能

IP鉴别头AH通过为IP数据包插入一个AH头来提供安全服务

AH能为IP数据包提供：

- 无连接完整性: 通过消息鉴别码产生的校验值来保证

为什么叫“无连接”： 因为它不需要像 TCP 那样先握手建立连接，确认连接后就不对IP包单独校验了，而是对每一个独立的 IP 包进行实时校验。

- 数据起源鉴别: 通过数据包中包含一个将要被验证的共享秘密或密钥来保证

在计算上面的“指纹”时，算法里不仅包含数据内容，还混入了一个只有发送方和接收方知道的秘密钥匙（Shared Secret）。

- 抗重放攻击: 通过在AH中使用一个序列号来实现。



2.1.3.2 AH的两种工作模式

根据AH头插入IP包的位置不同，AH有**传输模式**和**隧道模式**两种工作模式

传输模式



AH 头部被直接插入到原来的 IP 头部后面，紧接着数据载荷。

这个原IP头的协议字段将是51，以表明IP头之后的是一个AH头。

隧道模式



原 IP 头协议字段 = 原值 (如 6 或 17或1) 告诉接收方：最里面的载荷是 TCP 或 UDP或ICMP。

这个新的IP头的协议字段将是51，以表明IP头之后的是一个AH头。

2.1.4 负载安全封装(ESP)

2.1.4.1 描述

将整个IP分组或上层协议部分（即传输层协议数据，如TCP、UDP或ICMP协议数据）封装到一个ESP载荷之中，然后对此载荷进行相应的安全处理，如加密处理、鉴别处理等，实现对通信的**机密性**和**完整性**保护。

ESP只鉴别ESP头之后的信息，比AH鉴别的范围窄，AH还要对外部IP头各部分进行鉴别。

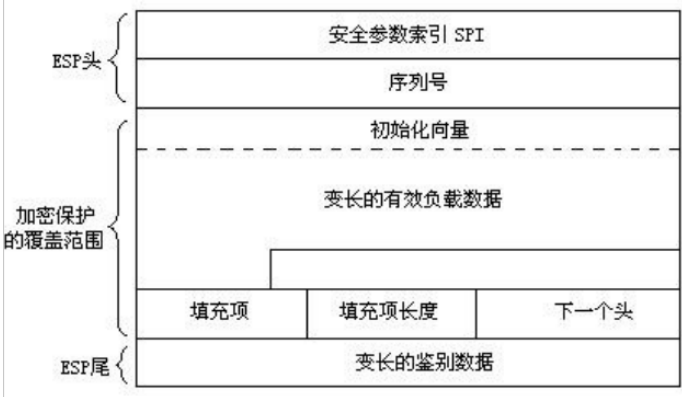
由于ESP除具备AH的全部功能外还用于确保数据包的机密性，因此每个ESP的SA(Security Association)都必须同时定义两套算法：负责保护机密性的加密算法和负责进行身份验证的鉴别算法

2.1.4.2 格式

序列号（SN）是一个单向递增的计数值，用于防止重放攻击；

填充项是根据加密算法的需要填满一定的边界，即使不使用加密也需要填充到四字节边界(32位)；缺省第一字节为1，后面的字节递增。填充长度则用来指出填充字段的长度，记录定义了多少填充，以供接收端恢复载荷数据的真实长度。

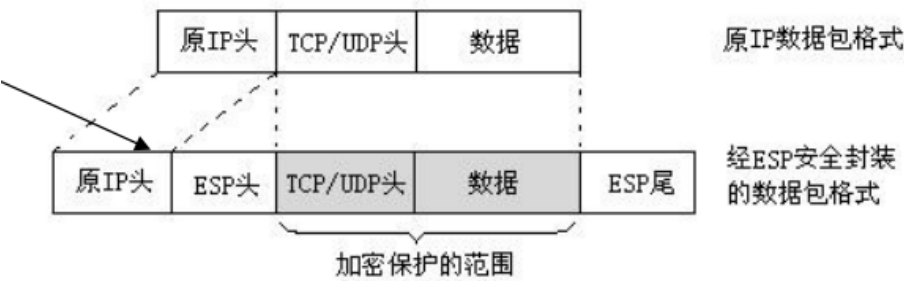
鉴别数据是进行数据完整性计算的结果，即ESP数据的完整性校验值（ICV）。若SA未指定鉴别算法，则无该字段。



2.1.4.3 ESP的两种工作模式

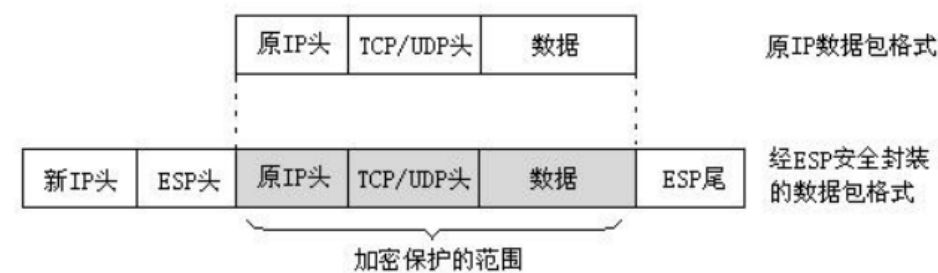
根据ESP封装的载荷内容不同，ESP头可选用两种方式中的一种来应用于IP数据包，即传送模式或隧道模式，其间的差别决定了**ESP保护的真正对象是什么**。

传输模式



这个原IP头的协议字段将是50，以表明IP头之后的是一个ESP头。

隧道模式



这个原IP头的协议字段将是51，以表明IP头之后的是一个ESP头。

隧道模式的ESP实施有如下的特点：保护子网中的所有用户都可以透明地享受由安全网关提供的安全保护；子网内部可以使用私有IP地址，无须公共IP地址资源；子网内部的拓扑结构被保护等。

2.2 SSL协议

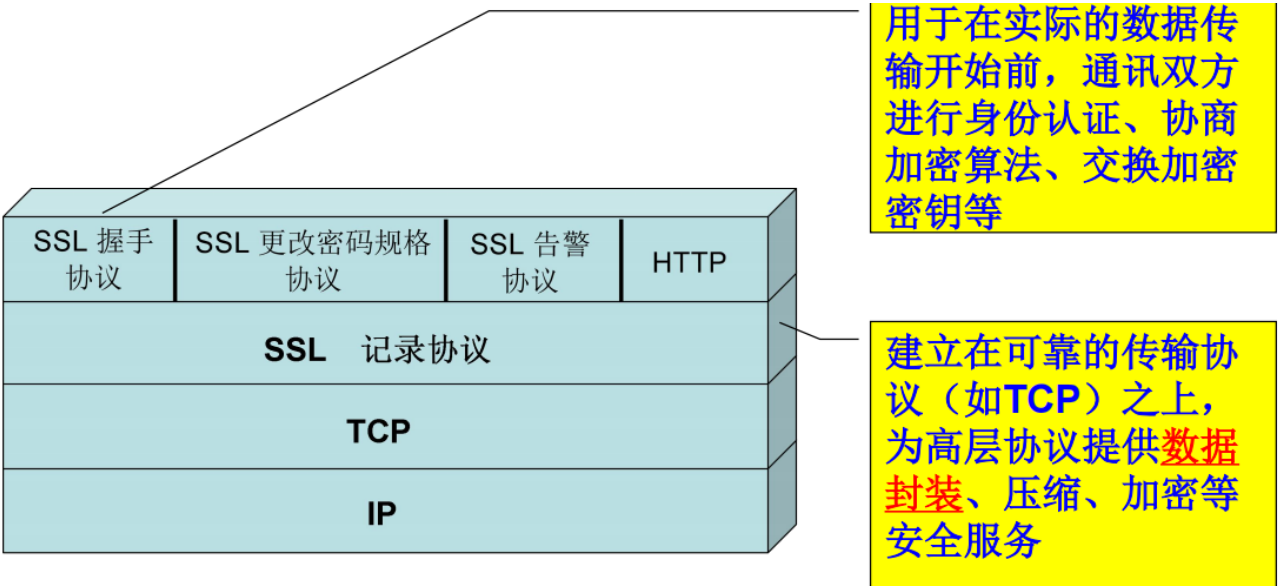
Secure Sockets Layer （安全套接层），广泛地用于Web浏览器与服务器之间的身份认证和加密数据传输。

2.2.1 提供的服务

- 1. 认证用户和服务器，确保数据发送到正确的客户机和服务器
- 2. 加密数据以防止数据中途被窃取
- 3. 维护数据的完整性，确保数据在传输过程中不被改变

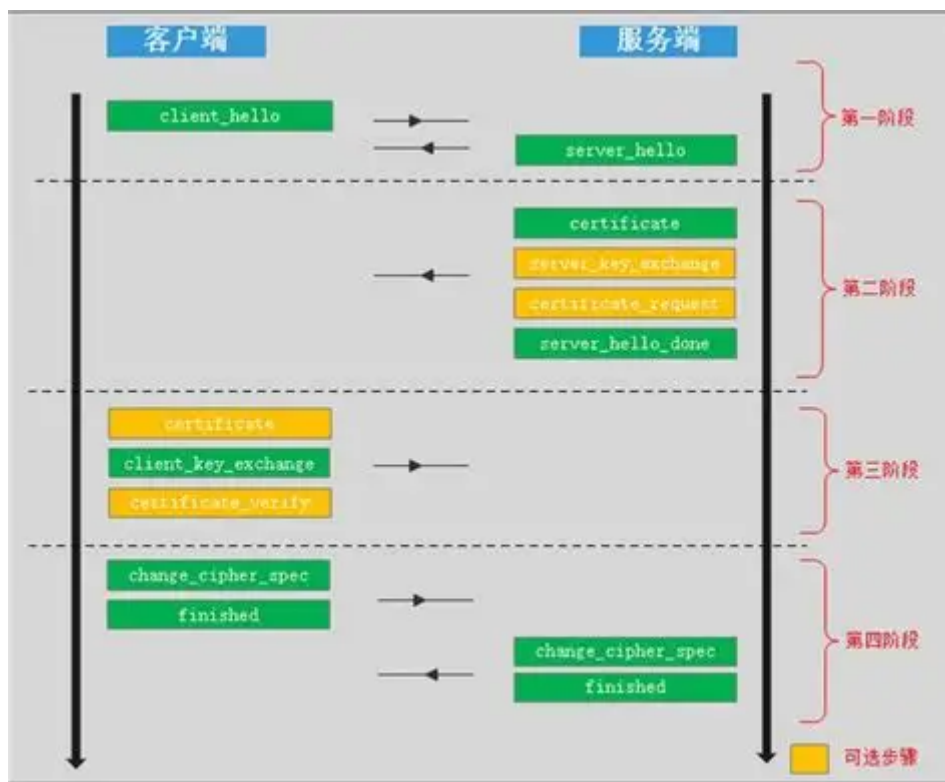
2.2.2 SSL协议框架

SSL协议分为两层



SSL握手协议行为过程

- 1. 客户端Hello：客户端向服务器发送支持的协议版本、加密套件和随机数。
- 2. 服务器Hello：服务器选择协议版本、加密套件，并发送自己的随机数。
- 3. 证书交换：服务器发送其数字证书，客户端验证证书的有效性。
- 4. 密钥交换：客户端和服务器协商并交换用于对称加密的会话密钥。
- 5. 完成握手：双方确认握手完成，开始加密通信。



在客户机和服务器之间建立逻辑连接必须的初始交换有4个阶段，分为

第1阶段：建立安全能力（协议版本、会话ID、密码组、压缩方法和初始随机数字）

第2阶段：服务器身份验证和密钥交换

（服务器可以发送证书、密钥交换和请求证书。服务器信号以hello消息段结束）

第3阶段：客户机验证和密钥交换（客户机可以发送证书。客户机发送密钥交换。客户机可以发送证书验证）

第4阶段：完成（更改密码组并完成握手协议）

2.2.3 TLS与SSL

TLS（传输层安全协议）的前身是 SSL (Secure Sockets Layer)。虽然现在大家习惯说“SSL 证书”，但实际上绝大多数场景使用的都是 TLS 协议。

与SSLv3有若干不同

1. 版本号：目前的TLS方案，主要版本是3，次要版本是1
2. 消息验证码：实际算法及MAC的计算范围不同

2.2.4 SSL应用实例——HTTPs

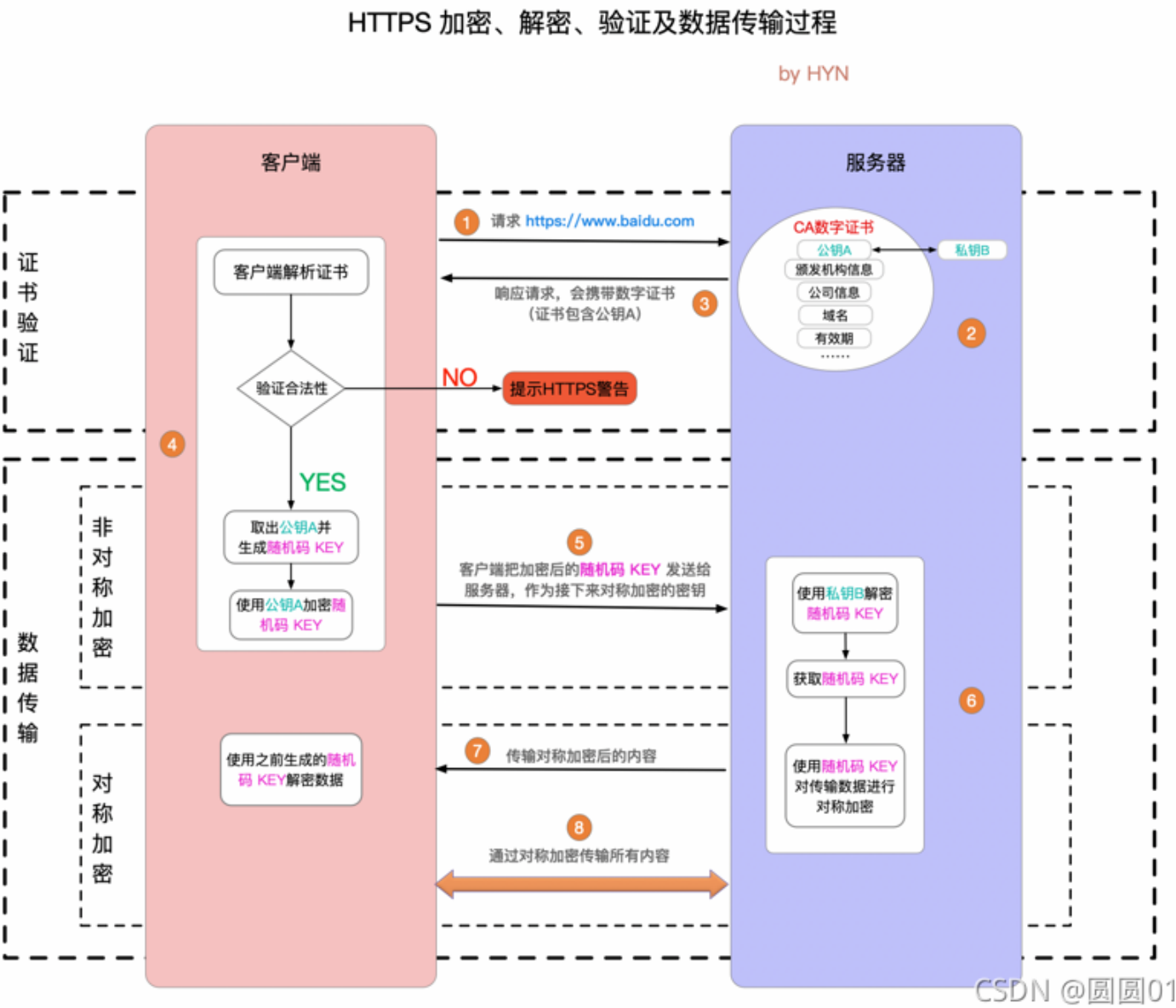
描述

HTTPS的安全基础是SSL，通过结合HTTP和SSL来实现Web浏览器和Web服务器之间的安全通信。

HTTPS已经融合在当今的Web浏览器中，只要Web服务器支持HTTPS，就可以使用。

HTTPS现在已广泛用于Internet上的安全B/S应用，例如网上交易等

通信过程（单项鉴别）



2.2.5 SSL的安全性

不符合《商用密码管理条例》中对商用密码产品不得**使用国外密码算法**的规定。

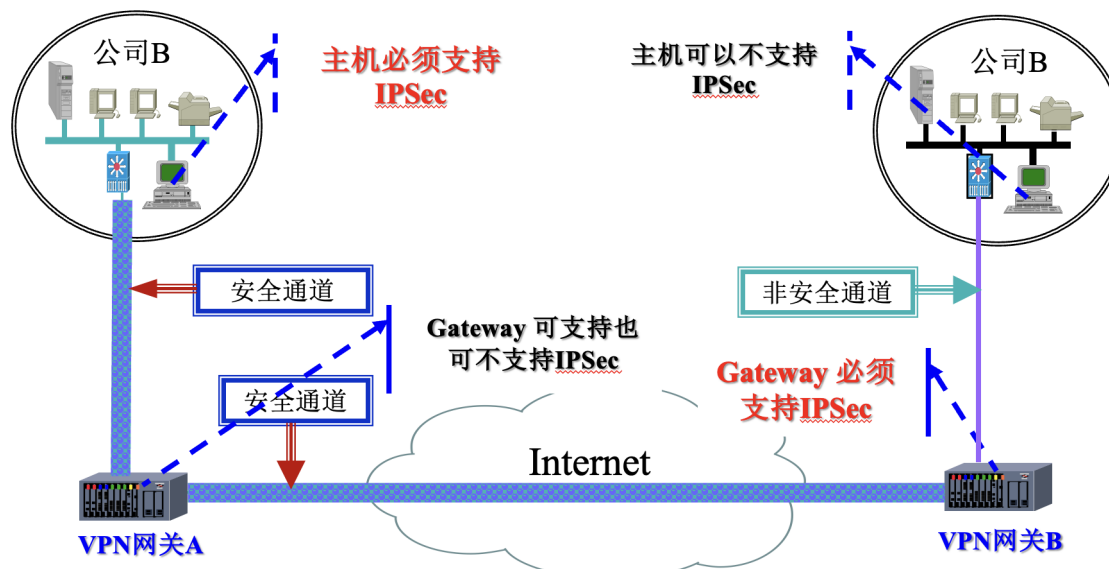
系统安全性还不够强。SSL协议的数据安全性其实就是建立在RSA等算法的安全性上，因此从本质上来讲，**攻破RSA等算法就等同于攻破此协议**。

3. VPN通道的建立方式

Host2host

Host2vpn网关

3.2 VPN通道的建立方式（Host to VPN）



vpn2vpn网关

remote user 2 VPN网关

CH11 系统安全

1. 漏洞分析方法

1.1 静态分析

- 通过对源代码、字节码或可执行文件等**静态数据**进行分析来发现潜在漏洞和安全问题的过程。
- 在静态分析过程中，不需要运行程序，而是通过检查代码本身来识别潜在的漏洞
- 通常包括源代码审计、代码扫描和抽象语法树分析等技术

1.2 动态分析

动态分析是一种采用**运行时数据**来分析软件漏洞和安全问题的方法。

动态分析通常涉及执行软件程序，监视其行为，并记录程序运行时产生的数据。

这种方法可以帮助发现程序的潜在漏洞，如内存泄露、缓冲区溢出、逻辑漏洞等，并帮助安全专家深入了解漏洞的原因和影响。动态分析通常比静态分析更有针对性，因为它可以提供有关程序运行时行为的详细信息。

1.3 模糊测试

1.3.1 定义

一种自动化的动态安全测试方法，旨在发现软件系统中的漏洞和异常行为。

1.3.2 基本前提

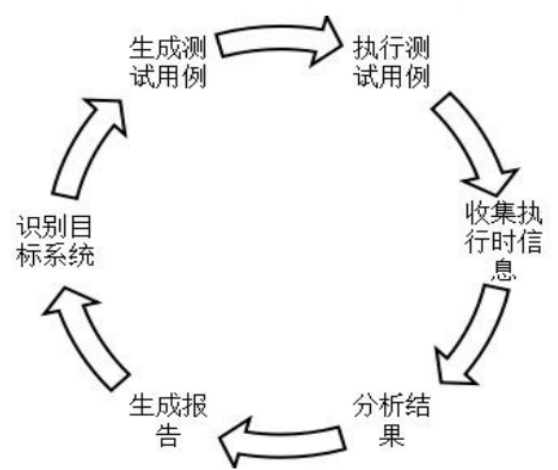
故意引入随机、异常的输入到系统中以识别故障。

1.3.3 关键组成部分

- 生成器
- 执行引擎
- 结果分析器

1.3.4 基本流程

在模糊测试过程中，会向目标软件系统输入大量随机、异常或非预期的数据，监控系统的反应，并检测系统在处理这些数据时是否会出现问题，如崩溃、内存泄露或安全漏洞。



2. 数据安全的定义

国家标准定义

通过管理和技术措施，确保数据有效保护和合规使用的状态。

法律定义

数据是任何以电子或以其他方式对信息的记录，数据安全是通过必要措施，确保数据有效保护和合法利用，以及具备保障持续安全状态的能力。

3. 现代隐私保护方法:联邦学习

联邦学习旨在不集中数据的情况下进行模型训练。联邦学习通过在分布式设备上
进行本地计算，避免了数据的集中存储和传输，从而增强了数据隐私保护，同时有效
利用分布式资源进行协同学习。

联邦学习的核心是**将模型训练分布在多个参与方**（如个人设备、企业或机构）之间，每个参与方在本地训练模型，然后将训练结果（如模型参数）发送到中央服务器进行聚合。**在这个过程中，数据从不离开参与方的设备**，只有训练后的模型参数被共享，从而保护数据隐私。

